Cybersecurity Dreigingsbeeld voor de zorg 2024

De Nederlandse zorg digitaal veilig

Colofon

Stichting Z-CERT is hét expertisecentrum op het gebied van cybersecurity in de zorg. Het jaarlijkse Cybersecurity Dreigingsbeeld voor de zorg beschrijft de belangrijkste gevaren voor de Nederlandse zorgsector. We gebruiken hiervoor de informatie uit meldingen van deelnemers, informatie van (inter-)nationale partners en kennisinstituten, eigen bevindingen, interviews met deskundigen, literatuuronderzoek, research van open bronnen en een enquête onder Nederlandse zorginstellingen.

Z-CERT is in 2017 opgericht op initiatief van de Nederlandse Vereniging van Ziekenhuizen (NVZ), Nederlandse Federatie van Universitair Medische Centra (NFU) en de Nederlandse GGZ. Z-CERT is een stichting en heeft geen winstoogmerk. We vormen een professioneel netwerk met de bij ons aangesloten zorginstellingen, het Nationaal Cyber Security Centrum (NCSC), Health-ISAC (Information Sharing and Analysis Center), brancheorganisaties, leveranciers en andere Computer Emergency Respons Teams (CERT's). Met elkaar pakken we cyberdreigingen aan, zoals ransomware, phishing, datalekken en hacken.

De inhoud van dit Cybersecurity Dreigingsbeeld voor de zorg 2024 is met grote zorgvuldigheid samengesteld. Toch kan er onverhoopt een fout of onvolledigheid in zijn geslopen. Z-CERT en eventuele andere betrokken partijen kunnen daarvoor niet aansprakelijk worden gesteld.

Inhoudsopgave

Colofon	2
Inhoudsopgave	3
Voorwoord	4
Samenvatting - Dreigingsbeeld 2024	6
Uitleg Dreigingsradar	8
Incidenten onder respondenten	10
Dreiging - Ransomware	12
Dreiging - Credential Phishing	18
Dreiging - Malware gericht op gebruikers	24
Dreiging - Financiële fraude	30
Dreiging - Ransomware in de leveranciersketen	32
Dreiging - DDoS	36
Dreiging - DDoS bij leveranciers	42
Dreiging - Cyberspionage door statelijke actoren	44
Dreiging - Insider threats	48
Dreigingsscenario's conflict Rusland en Oekraïne	54
Uitleg over Dreigingsradar	56
Dankwoord	59
Bibliografie	60

Voorwoord

De beveiliging van gevoelige patiëntgegevens en kritieke digitale infrastructuren is belangrijker dan ooit. Zorgorganisaties moeten anticiperen op cyberdreigingen. Niet alleen vanwege strengere wetgeving, maar ook door de toegenomen cyberdreiging. Die dreiging groeit onder meer doordat zorgorganisaties steeds meer gebruikmaken van digitale technologieën, zoals zorg op afstand en domotica.

Het jaar 2024 heeft ons geconfronteerd met een breed scala aan uitdagingen en cyberdreigingen op het gebied van cybersecurity binnen de zorg. Van de opkomst van nieuwe ransomware-groepen tot verfijnde phishing-campagnes, het zijn dreigingen die voortdurend evolueren.

De strengere wetgeving en normen die in de zorg gelden, verlangen van organisaties dat ze hun basisbeveiliging op orde hebben. Het besef van wat de mogelijke impact van een cyberincident zou kunnen zijn, is nog niet overal aanwezig.

"Je moet er niet aan denken dat een groot academisch ziekenhuis uitvalt tijdens een crisissituatie..."

Wij pleiten voor realistische testen en simulaties binnen de zorgsector, vergelijkbaar met de praktijkvoorbeelden uit de banksector. In sectoren als onderwijs en wetenschap zien we instellingen soms dagenlang uitvallen. Dat is al zorgwekkend, maar in de zorgsector is dat onacceptabel. Je moet er niet aan denken dat een groot academisch ziekenhuis uitvalt tijdens een crisissituatie.

Europese samenwerking is nodig

Ook in Europees verband kunnen we nog veel van elkaar leren. Wij blijven de urgentie van betere samenwerking binnen Europa om de toenemende cyberdreigingen te bestrijden benadrukken. De geopolitieke situatie stelt ons voor nieuwe uitdagingen. Terwijl criminelen profiteren van zwakke plekken in de digitale infrastructuur, blijven cruciale spelers in de zorgsector onvoldoende samenwerken en aarzelen om gevoelige informatie te delen.

Het is goed dat de Europese Commissie in januari het actieplan introduceerde om de cyberveiligheid van Europese zorginstellingen te versterken. Dit is een belangrijke stap om de patiëntveiligheid en de continuïteit van zorgprocessen te beschermen, die door cyberaanvallen ernstig kunnen worden bedreigd.

Wij roepen zorginstellingen, overheden en andere betrokken partijen op om nu de handen ineen te slaan en gezamenlijk actie te ondernemen. Om dit statement kracht bij te zetten, hebben we besloten om het vijfde jaarlijkse Dreigingsbeeld voor de zorg te presenteren in Brussel, het hart van de Europese democratie.

In dit Cybersecurity Dreigingsbeeld voor de zorg bieden we inzicht in de huidige staat van cyberveiligheid in de zorg. We beschrijven de lessen die we het afgelopen jaar hebben geleerd en geven handelingsperspectieven die kunnen helpen bij een beter digitaal beschermde zorgsector. Laten we er samen voor zorgen dat we de zorgsector in 2025 nog beter kunnen beschermen tegen de steeds veranderende cyberdreigingen.

Wim Hafkamp - Directeur Z-CERT

Samenvatting Dreigingsbeeld 2024

Z-CERT ziet in 2024 opnieuw een toename in het aantal digitale aanvallen tegen zorgorganisaties. Criminele hackers, digitale spionnen en hacktivisten zien zorgorganisaties als legitiem doelwit om af te persen en gegevens van te stelen; ongeacht de gevolgen, zoals het verstoren van zorgprocessen. In 2024 hebben meerdere digitale aanvallen plaatsgevonden tegen zorginstellingen met impact op de zorgprocessen in Nederland en elders in Europa.

Digitale afpersing: geld of je leven

Z-CERT heeft in 2024 verschillende vormen van digitale afpersing waargenomen, zoals via ransomware en datalekken. Zowel lokale IT als ook cloudomgevingen waren het doelwit. Wat opvalt is dat elke zorginstelling, ongeacht type en grootte, een mogelijk doelwit is.

Digitale aanvallen op de leveranciersketen

Naast de zorgorganisaties zijn ook een flink aantal Europese en Amerikaanse leveranciers van zorgorganisaties getroffen. Verstoring in de processen door ransomware en datalekken bij deze leveranciers heeft directe gevolgen gehad voor de betrokken zorgorganisaties. Zo heeft een ransomware-aanval op een pathologische dienstverlener in Engeland als impact gehad dat huisartsen geen bloedtesten konden afnemen en duizenden poliklinische afspraken moesten worden uitgesteld.

Behalve digitale afpersing ziet Z-CERT ook DDoS-aanvallen als een verhoogd risico op het functioneren van de leveranciersketen, bijvoorbeeld wanneer een EPD-leverancier wordt geraakt. Nederlandse zorgorganisaties waren in 2024, in tegenstelling tot 2023, zelf minder vaak het doelwit van DDoS-aanvallen.

Gelegenheid maakt de digitale dief

Afpersing met ransomware en datalekken is meestal het gevolg van opportunistische digitale aanvallen, waarbij kwaadwillenden bijvoorbeeld succesvol gebruik maken van kwetsbaarheden in soft- en hardware. Daarnaast blijven hackers nepberichten versturen naar zorginstellingen om persoonlijke

informatie te stelen. Tot slot zijn ook digitale incidenten veroorzaakt door (ex-) medewerkers en digitale financiële fraude terugkerende fenomenen.

Spionage: privacy en technologie

Digitale spionnen richten zich in de Nederlandse zorgsector vooral op het stelen van wetenschappelijk onderzoek, intellectuele eigendommen en grote hoeveelheden biomedische- en persoonlijke data. Daarnaast ziet Z-CERT in toenemende mate risico's met betrekking tot hard- en software afkomstig uit landen met een geavanceerd en omvangrijk offensief cyberprogramma, zoals Rusland, China, Noord-Korea en Iran.

Trends: aanval op de cloud, AI-gedreven nepberichten

Omdat gegevens zoals die van medewerkers, patiënten en onderzoek naar de cloud gaan, richten kwaadwillenden hun aandacht op het hacken van de cloudbeveiliging.

AI-modellen zijn nu al net zo goed als mensen in het maken van overtuigende nepberichten voor phishing campagnes. Z-CERT denkt dat AI hierin steeds realistischer wordt en steeds vaker hiervoor gebruikt zal worden.

Dreigingsradar

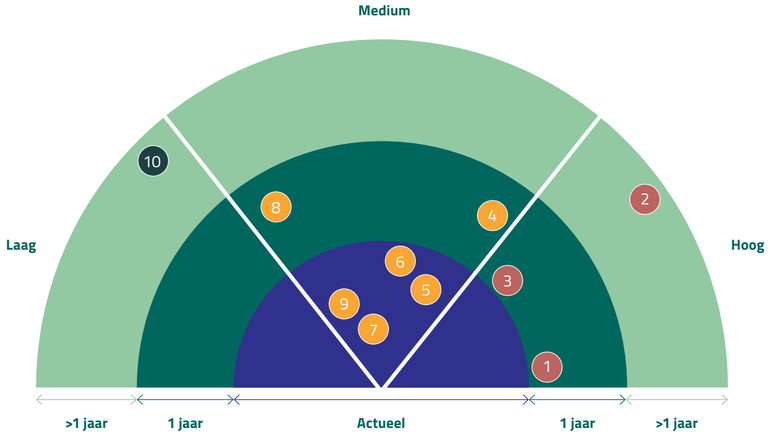
De dreigingsradar geeft de tijd, de impact en daarmee de ernst van de dreiging weer voor de zorg. De plaats van de diverse bolletjes in de binnenring, middenring of buitenste ring zegt iets over wanneer iets een dreiging zal zijn.

De grafiek is ingedeeld in drie taartpunten die iets zeggen over de weging van de dreiging. In de rechter taartpunt staan de ernstigste dreigingen. Hoe meer de bolletjes naar links staan, hoe lager de dreiging is die ervan uitgaat.

Tot slot geeft de kleur van de bolletjes de verwachte impact van een dreiging aan. De kleuren komen overeen met de kleuren van een stoplicht.

Een uitgebreide uitleg van de dreigingsradar staat op pagina 56.

Goed om te weten: In het Dreigingsbeeld bieden we per dreiging zogenaamde handelingsperspectieven aan. Dit zijn adviezen waarbij wij verwijzen naar CIS Controls. De CIS Controls (Critical Security Controls) zijn een reeks beproefde methoden die organisaties vaak gebruiken om maatregelen uit de NEN 7510 of ISO 27001 praktisch in te richten. In dit Dreigingsbeeld voor de zorg verwijzen we regelmatig naar deze CIS Controls zodat het eenvoudiger wordt om aandachtspunten te implementeren. **Meer lees je op cissecurity.org/controls**



1. Ransomware met afpersen en datalek
2. Spionage (onderzoek)
3. Ransomware bij leverancier
4. DDoS bij leverancier
5. Credential phishing
6. Malware
7. Insider threats
8. DDoS
9. Financiële fraude
10. Spionage (reguliere zorginstellingen)

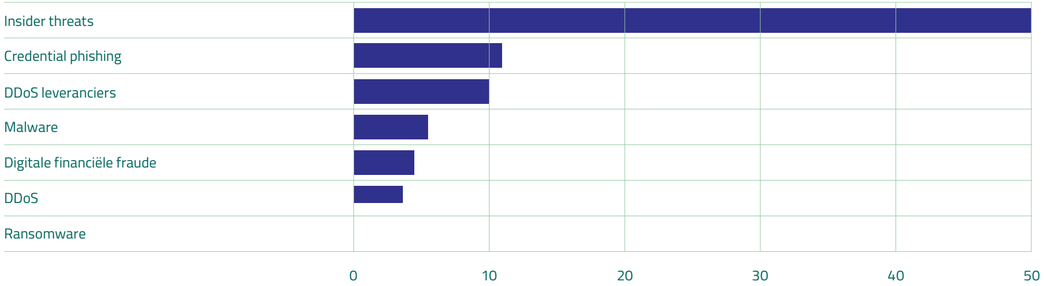
Incidenten onder respondenten

Voor het dreigingsbeeld heeft Z-CERT bij deelnemers geïnformeerd naar het type security-incidenten dat zij hebben meegemaakt. Bijna een vierde van de deelnemers heeft deze survey ingevuld. De resultaten worden hieronder weergegeven in een grafiek. Deze informatie kan worden gebruikt om bewustwording te creëren binnen uw eigen organisatie en om maatregelen te prioriteren. De incidenten zullen verder besproken worden in de hoofdstukken over 'dreigingen' en zijn onder andere gebruikt om de dreigingsniveaus vast te stellen.

Toelichting

Het percentage geeft weer hoeveel procent van het totaal aantal respondenten één of meerdere incidenten hadden in deze categorie. Bij de financiële fraude categorie in de grafiek gaat het om financiële fraude die gepleegd is door gebruik te maken van digitale media als mail en WhatsApp. Bij de categorie 'malware' in deze grafiek gaat het specifiek om malware die ontworpen is om gebruikers te verleiden deze malware op te starten. De categorie 'insider threats' is omvangrijk. Het gaat in dit dreigingsbeeld om datalekken die het gevolg zijn van onopzettelijkheid, nalatigheid, nieuwsgierigheid en kwaadwillend handelen door interne en externe betrokkenen, zoals medewerkers, leveranciers en ingehuurde krachten.

Figuur 1: Security-incidenten die plaatsvonden bij deelnemers van Z-CERT die de vragenlijst hebben ingevuld



Dreiging
Ransomware

Dreiging - Ransomware

Inschatting dreiging: Hoog

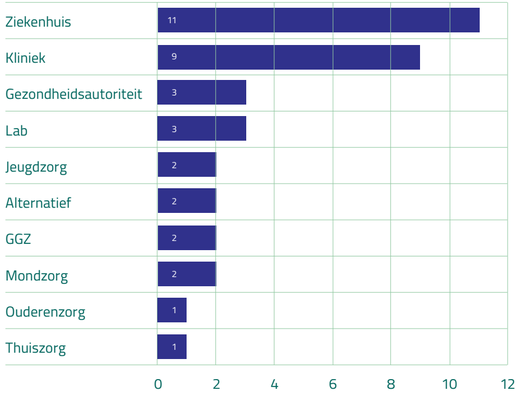
Z-CERT schat het dreigingsniveau door ransomware en/of afpersen met datalekken in als 'hoog'. In dit hoofdstuk bedoelen we met datalekken: publicatie van gegevens op datalekwebsites. We schatten in dat de kans op een incident licht gestegen is ten opzichte van vorig jaar. Onder andere omdat in 2024 'AiTM-phishing' gemeengoed is geworden in cybercrime en de cloud steeds vaker doelwit is. Z-CERT verwacht in 2025 enkele incidenten.

Incidenten en impact

In 2024 werden wereldwijd 12 procent meer incidenten gepubliceerd op datalekwebsites van ransomware-actoren dan in 2023. In de zorg in Europa zagen we een stijging van 25 procent. In Nederland werden er in totaal twee organisaties uit de zorgsector geraakt: één jeugdzorgorganisatie en één aan mondzorg gerelateerde organisatie. Dat zijn twee incidenten minder dan in 2023. Daarnaast kon een revalidatiekliniek een ransomware-incident op het nippertje voorkomen.

Wat opvalt is dat een grote diversiteit aan zorginstellingen geraakt (figuur 2) werd. Het laat zien dat elk type zorginstelling in principe een potentieel slachtoffer is. Daarnaast laat de analyse over organisatiegrootte zien, dat zorgorganisaties van verschillende groottes (figuur 3) doelwit zijn. De zorgsector was de op twee na meest geraakte sector in 2024.

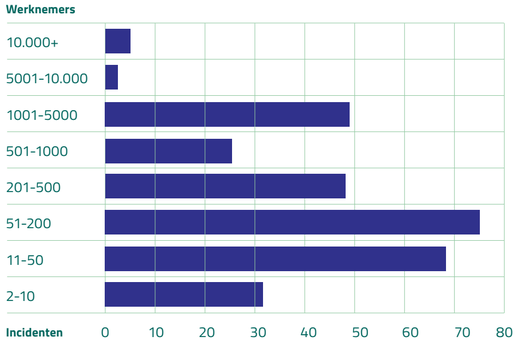
Figuur 2: Incidenten per zorgorganisatietype in Europa in 2024



Incidenten waarbij zorgaanbieders in Europa in 2024 werden afgeperst met het lekken van data, ransomware- of een combinatie van beide. Gegevens afkomstig van datalekwebsites of open bronnen.

Dreiging - Ransomware, vervolg

Figuur 3: Incidenten per grootteklasse zorgorganisatie wereldwijd in 2024



Incidenten waarbij zorgaanbieders wereldwijd in 2024 werden afgeperst door het lekken van data, ransomware- of een combinatie van beide. Data komt van datalekwebsites van cybercriminelen.

Ransomware of afpersen met datalekken

Van de genoemde incidenten is niet altijd duidelijk of het gaat om ransomware-aanvallen in combinatie met datalekken of dat het alleen gaat om afpersing met datalekken. Ook in 2024 waren er weer ransomware-actoren die het versleutelen van bestanden achterwege lieten en alleen nog maar afpersten met datalekken [1] [2] [3]. Dit is een effectieve manier om geld te verdienen; vaak betaalt 20 tot 50 procent van de getroffen organisaties het losgeld. Bovendien kost de aanval minder tijd en resources [4]. Juist voor de zorgsector is dat een relevant verschil omdat alleen bij het versleutelen van bestanden de zorgcontinuïteit direct in gevaar is.

Tegelijkertijd verwerkt een zorgaanbieder veel bijzondere persoonsgegevens en is dus een aantrekkelijk doelwit. De data staan vaak opgeslagen in cloudgebaseerde SaaS-applicaties en juist deze applicaties zijn regelmatig doelwit. In Frankrijk kon een kwaadwillende bijvoorbeeld met een eenvoudig gestolen wachtwoord toegang krijgen tot een account met hoge rechten en zo data van ruim 750.000 patiënten inzien [5]. In Australië kon een actor inloggen op een radiologieportaal en toegang krijgen tot tienduizenden patiëntgegevens, inclusief de resultaten van beeldvormend onderzoek, door een gelekt wachtwoord te gebruiken [5]. Naast zorggerelateerde platformen waren er in 2024 diverse voorbeelden van afpersincidenten waarbij data afkomstig was van veelgebruikte cloudoplossingen, zoals SharePoint [6] [7] [1].

Impact

Uit een onderzoek [8] naar ransomware-incidenten in de internationale zorgsector kwam een aantal zaken naar voren:

- 22 procent van de geraakte zorgorganisaties kon binnen een week herstellen, 37 procent had meer dan een maand nodig en 7 procent zelfs meer dan drie maanden.
- Bij 95 procent van de zorginstellingen werden ook back-ups geraakt door ransomware. Organisaties waarbij de back-up geraakt werd, betaalden 3x hogere losgeldbedragen dan organisaties waarbij de back-ups niet geraakt waren.
- Herstelkosten waren gemiddeld 2,57 miljoen euro (exclusief het losgeld).
- Gemiddeld 57 procent van de apparaten verbonden aan het netwerk werd geraakt.

Bij veel door Z-CERT geregistreerde incidenten kon de impact op zorg niet worden vastgesteld. Bij een beperkt aantal incidenten in Europa kon dit wel:

- Bij minstens 4 zorgorganisaties was er impact op spoedeisende hulp.
- Bij minstens 7 zorgorganisaties moesten afspraken worden uitgesteld.
- Bij minstens 5 zorgorganisaties moesten patiënten of cliënten handmatig (pen en papier) geregistreerd worden.

Dreiging - Ransomware, vervolg

Trends, methoden en technieken

Uit een onderzoek naar ransomware in de zorg [8] worden de volgende technieken genoemd als de eerste stap om binnen te komen:

- Misbruik van kwetsbaarheden
- Inloggen met een gestolen of gelekt wachtwoord
- Malware die via mail binnenkwam
- Credential phishing

Bovenstaande technieken zijn ook door Z-CERT waargenomen bij ransomware-incidenten in de Nederlandse zorg. Z-CERT adviseert daarom de weerbaarheid tegen deze technieken prioriteit te geven. Hoe eerder een incident gestopt kan worden, hoe kleiner de impact.

In 2024 waren er een aantal trends zichtbaar:

- Z-CERT observeert dat er steeds meer voorbeelden zijn van ransomware en data-exfiltratie incidenten in de cloud en de combinatie cloud en de lokale IT-omgeving [9] [10] [11].
- Afgelopen jaar constateerde Z-CERT dat er veel kwetsbaarheden in edge-devices zoals firewalls en VPN-oplossingen actief misbruikt werden. Tevens werden door Z-CERT veel pogingen gezien om in te loggen op deze VPN-oplossingen met geraden of gestolen wachtwoorden.
- Wij krijgen signalen uit de sector dat sommige leveranciers nog niet voldoen aan de principes van moderne authenticatie, zoals het gebruik van MFA. Omdat deze leveranciers toegang hebben tot meerdere zorginstellingen, kan dit een risico zijn voor de sector.

Specifieke aanbevelingen voor 2025

Gegeven de laatste ontwikkelingen in het dreigingslandschap willen we graag de volgende aanbevelingen extra onder de aandacht brengen:

- Zorg dat een aanvaller niet vanaf het lokale netwerk naar de cloud kan bewegen of andersom. Een lokaal account met veel rechten moet bijvoorbeeld niet gebruikt kunnen worden in de cloud [12].
- Overweeg in uw cloudomgeving functionaliteit te gebruiken om data-exfiltratie te detecteren en te voorkomen.
- Onderzoek of uw cloudomgeving bestand is tegen ransomware-aanvallen en of uw cloudomgeving in staat is ransomware-activiteit te detecteren.
- Overweeg back-ups van uw cloudomgeving regelmatig te maken en deze offline en versleuteld te bewaren.

- Besteed bij leveranciersmanagment aandacht aan leveranciers die nog geen gebruik maken van principes van moderne authenticatie zoals MFA, tijdelijke toegang op aanvraag (just in time adminstration) en rechten op maat (least privileges).
- Overweeg voor toegang met verhoogde rechten alternatieven voor VPN-oplossingen, zoals 'zero trust network access' (ZTNA) oplossingen. Ook bieden Privileged Access Management oplossingen een betere controle over toegang met verhoogde rechten en zorgen dat toegang alleen binnen het afgesproken tijdsframe kan plaatsvinden [13].

Algemene aanbevelingen:

- Raadpleeg de nieuwe publicatie van het NCSC over het beheersen van risico's van edge devices (zoals VPN-oplossingen) [14].
- Raadpleeg de publicatie van het NCSC voor gedetailleerde informatie over ransomware en incident response [15].
- Om structureel en concreet te werken aan weerbaarheid tegen ransomware raden wij de implementatie van NEN 7510 en CIS Controls aan [16]. De CIS controls bieden verschillende volwassenheidsniveaus, zodat elk type organisatie ermee aan de slag kan.
- Overweeg om voor het 'hardenen' van software en systemen security baselines te gebruiken zoals de CIS benchmarks [16] of de Microsoft Security baselines [17].
- Voor specifieke informatie over maatregelen tegen veel hackingtechnieken is een gedetailleerde gids online beschikbaar [18].

Dreiging
Credential Phishing

Dreiging - Credential Phishing

Inschatting dreiging: Medium

Dit deel van het dreigingsbeeld zoomt in op phishing om authenticatiegegevens te verkrijgen. Z-CERT schat het dreigingsniveau voor deze vorm van phishing binnen de zorg in als 'medium'. Pogingen tot phishing vinden constant plaats en slagen ook geregeld. De dreiging die van phishing uitgaat lijkt op zichzelf niet hoog, maar een gecompromitteerde mailbox kan het begin zijn van een serieus incident, zeker als toegang tot de mailbox gelijk staat aan toegang tot het platform (OneDrive, SharePoint, etc.). Als er eenmaal toegang is verkregen, kan dat een opstapje zijn naar bijvoorbeeld een ransomware-incident of financiële fraude. Z-CERT verwacht in 2025 op maandelijkse basis phishingincidenten waarbij met succes toegang wordt verkregen tot online werkplekken.

Incidenten en impact

Phishing als techniek is constant in ontwikkeling. Elke dag wordt er een continue stroom van phishingmail verstuurd. 16 procent van de respondenten in de survey voor dit dreigingsbeeld, meldde dit jaar een geslaagde phishingaanval. In 69 procent van de gevallen betrof het credential phishing. Hoewel phishing met QR-codes nog steeds werd gezien, komt phishing door middel met malafide links het meest voor.

AiTM phishing

In het najaar van 2024 was er een aantal zeer succesvolle Adversary-in-The-Middle (AiTM) phishingcampagnes actief in de zorgsector. Bij dit type aanval plaatst de aanvaller zich tussen het slachtoffer en een platform waarop wordt geauthenticeerd (vaak Microsoft 365). De aanvaller lift mee op het hele inlogproces van de gebruiker zodat MFA geen barrière vormt voor toegang. Z-CERT heeft in die periode veel meer meldingen ontvangen van gecompromitteerde accounts dan gebruikelijk. In oktober en november heeft Z-CERT elf gevallen geregistreerd. Daarnaast vernamen wij het lekken van inloggegevens van vijftig accounts, voortkomend uit onder andere AiTM-aanvallen. Opmerkelijk is dat een deel deze gevallen niet bekend was bij die zorginstellingen. Ook werd in sommige gevallen pas na vervolgonderzoek duidelijk dat er meer accounts waren geraakt dan eerder was gedetecteerd.

Dreiging - Credential Phishing, vervolg

Trends, methoden en technieken

Social enigineering, vertrouwd overkomen: In veel door Z-CERT waargenomen phishingcampagnes proberen kwaadwillenden zo vertrouwd mogelijk over te komen. Dat doen ze op verschillende manieren:

- In de phishingmails linken aanvallers vaak naar sites die gehost worden op vertrouwde platforms (Dropbox, SharePoint, e.d.) [19].
- De phishingmails worden vaak verzonden vanuit accounts van vertrouwde partijen die eerder gehackt zijn door de aanvaller.

Teams-phishing: In maart en april 2024 zijn er nog veel gevallen van Teams-phishing waargenomen [20]. Hierbij deelt een kwaadwillende links via een Teams-chat vanuit een gecompromitteerd account of een voor dat doel ingerichte tenant.

Phishingkits: Z-CERT ziet veel campagnes waarbij gebruik wordt gemaakt van phishingkits, die worden aangeboden op Phishing-as-a-Service (PaaS) platforms. Zonder technische kennis kan een kwaadwillende voor een vast bedrag per maand gebruikmaken van een online omgeving om sterk geautomatiseerde phishingcampagnes op te zetten. Er zijn diverse [21] [22] zelfs gratis varianten beschikbaar [23]. Dit verlaagt de drempel voor cybercriminelen om phishincampagnes op te zetten. Z-CERT verwacht komende jaren daarom dat de stroom van phishingmails alleen maar zal toenemen.

Generatieve AI: Z-CERT ziet dat phishing taalkundig beter wordt en vaker in het Nederlands is geschreven. Het is aannemelijk dat de inzet van AI hierbij een rol speelt. De mate waarop AI wordt ingezet, wordt door partijen verschillend beoordeeld [24] [25]. Z-CERT verwacht dat generatieve AI steeds meer ingezet zal worden om realistischere en specifiekere phishingmails te genereren. Op dit moment zijn AI-modellen net zo goed in het genereren van spearphishing mails als menselijke experts. Dit zal alleen maar beter worden [26] [27]. In de praktijk worden dergelijke aanvallen op leden van het hogere management inmiddels ook waargenomen [28].

Specifieke aanbevelingen voor 2025

Gegeven de laatste ontwikkelingen in het dreigingslandschap willen we graag de volgende aanbevelingen extra onder de aandacht brengen:

- Voorzie accounts met toegang tot gevoelige data van phishing resistente MFA. Zie de factsheet van het NCSC 'Volwassen authentiseren – gebruik veilige middelen voor authenticatie' [29].
- Gebruik toegangsbeleid waarbij ook context wordt meegenomen (in Microsoft-omgevingen 'conditional access policies' genoemd). Verleen bijvoorbeeld alleen toegang vanaf geregistreerde of compliant apparaten [30]
- Zorg dat medewerkers MFA niet kunnen uitzetten.
- Stel in dat wanneer gebruikers beveiligingsgegevens wijzigen (zoals een nieuwe MFA-methode), zij opnieuw moeten inloggen. Of dat zij deze wijzigingen überhaupt niet zelf kunnen maken.
- Maak een incident response-plan specifiek voor AiTM-phishing.
- Optimaliseer AiTM-phishing detectie [31].
- Zorg ook dat er opvolging wordt gegeven aan eventuele detectie.
- Overweeg detectie van het klonen van inlogpagina's om AiTM-aanvallen in een vroeg stadium te detecteren [32] [33].

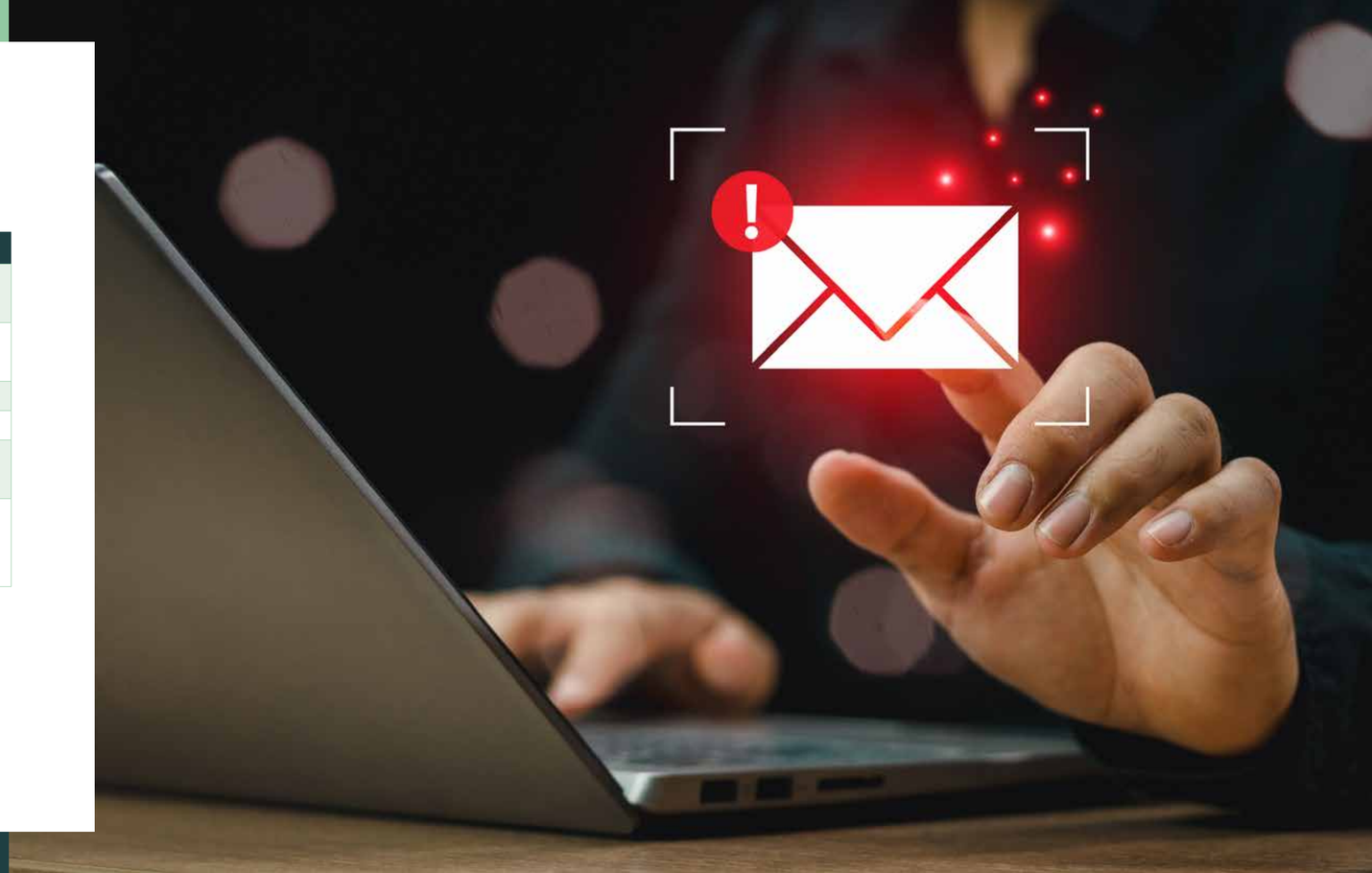
Aanbevelingen rondom andere vormen van phishing

- Voorkom Teams-phishing door te managen vanaf welke domeinen contact gelegd mag worden met medewerkers [34].
- Ga na of je e-mailbeveiliging ook voorziet in de detectie van malafide QR-codes [35].

Dreiging - Credential Phishing, vervolg

Algemene aanbevelingen

Aanbeveling	CIS control
Zorg voor een awareness-programma voor het herkennen van phishing, zie ook de NEN 7510-2 norm mensgerichte beheersmaatregel 6.3 [36].	14
Schakel de functionaliteit in die medewerkers de mogelijkheid geeft een mail gemakkelijk te markeren als phishing. Dit zorgt ervoor dat een cloudprovider sneller kan optreden en draagt bij aan detectie.	
Implementeer beveiligingsmaatregelen rondom e-mail en webbrowsers.	9
Richt access control en accountmanagement in volgens best practices.	5,6
Zorg voor voldoende logging van voldoende kwaliteit om misbruik van accounts te detecteren. Monitor op verdachte wijzigingen zoals het automatisch doorsturen naar externe accounts en het aanmaken van mailboxregels.	8
Om datalekken te voorkomen zijn maatregelen nodig ter bescherming van data van accounts/e-mailboxen. Systemen voor Data Loss Prevention (DLP) en bestandsclassificatie kunnen hierbij helpen. Sommige datamanagementoplossingen versleutelen de bestanden standaard waardoor bij diefstal de data niet is in te zien.	3



Dreiging
Malware gericht op gebruikers

Dreiging - Malware gericht op gebruikers

Inschatting dreiging: Medium

In dit hoofdstuk gaat het om malware (kwaadaardige software) waarbij een gebruiker wordt verleid om malware op te starten. Z-CERT schat het dreigingsniveau voor incidenten met malware bij zorginstellingen in als 'medium'. In veel gevallen is de impact van malware-incidenten waarbij de gebruiker de malware onbewust opstart, beperkt en wordt de infectie snel opgeruimd. Echter, een malware-infectie kan escaleren en een ransomware- of datalekincident tot gevolg hebben. Z-CERT verwacht in 2025 op maandelijkse basis malware-infecties waarbij in enkele gevallen de malware-infectie zal escaleren.

Incidenten en impact

Vier procent van de ondervraagden heeft in 2024 een incident met malware gehad. Daarnaast ontvingen we tientallen meldingen van gestolen wachtwoorden die via 'infostealer malware' waren verkregen. Deze wachtwoorden werden soms ook verkocht op het darkweb.

Z-CERT ziet in de Nederlandse zorg de volgende scenario's:

- Phishingmails met links naar malware of met malware als bijlage.
- Legitieme websites die zijn gehackt, waarbij nietsvermoedende bezoekers worden verleid malware te downloaden, bijvoorbeeld in de vorm van een malafide browserupdate. Ook kunnen malafide advertenties op (legitieme) websites worden geplaatst die doorverwijzen naar malware.
- Systemen worden besmet via een geïnfecteerde USB-stick.

Vaak wordt de infectie snel opgemerkt en beperkt de schade zich tot het opnieuw moeten opbouwen van de systemen. Het is belangrijk om je te realiseren dat mogelijk ook data, wachtwoorden en websessiecookies zijn gestolen. Dergelijke gegevens kunnen ook na systeemherstel worden misbruikt om de aanval te continueren.

Een malware-incident kan ook een voorloper zijn van een ransomware-incident. Bij enkele zorginstellingen werd malware aangetroffen die gebruikt wordt door ransomware-actoren. Sporen van actieve malware-infecties geassocieerd met ransomware-actoren werden gevonden, maar de infecties werden tijdig gemitigeerd.

Dreiging - Malware gericht op gebruikers, vervolg

Infostealers

Een populaire vorm van malware waarbij gevoelige data wordt gestolen, is de infostealer. Kwaadwillenden kunnen met infostealers bijvoorbeeld wachtwoorden, creditcardinformatie en websessiecookies stelen om met die gegevens in te loggen op afstandswerkoplossingen. Dit kan leiden tot ransomware-aanvallen of datalekken. Als websessiecookies worden gestolen, kan een aanvaller tijdelijk toegang krijgen tot de webapplicatie waarop de gebruiker was ingelogd. Een voorbeeld van een incident met veel impact vond plaats bij de politie [1], waar de contactgegevens van veel agenten werden gestolen. De politie vermoedt dat er een websessiecookie gestolen is via malware, waardoor de aanvaller toegang tot de applicatie kreeg zonder wachtwoord of MFA in te voeren. Omdat het systeem op basis van de cookie ervan uitging dat de gebruiker het loginproces al had doorlopen.

Trends, methoden en technieken

In 2024 waren infostealers een veel voorkomend type malware [37] [38]. Veel infostealers worden als een 'service' zeer goedkoop aangeboden zodat de drempel voor cybercriminaliteit wordt verlaagd. Ook worden er veel zogenaamde 'remote access trojans' gezien die een aanvaller toegang geven tot een computer. Deze toegang wordt soms ook verkocht op het darkweb. Wat betreft malware is er een 'race' gaande tussen de hackers en de antivirusleveranciers. Daarbij wordt door hackers continue gewerkt aan malware die niet gedetecteerd wordt door antivirussoftware. Generatieve AI helpt cybercriminelen om dergelijke malware sneller te ontwikkelen.

Legitieme 'externe toegangssoftware' wordt ook ingezet als malware. Hierbij kan een aanvaller de computer overnemen om vervolgens een aanval uit te voeren. Een aanvaller lift mee op autorisaties van de gebruiker en krijgt toegang tot alle applicaties waar 'single sign-on' is ingeschakeld.

Specifieke aanbevelingen voor 2025

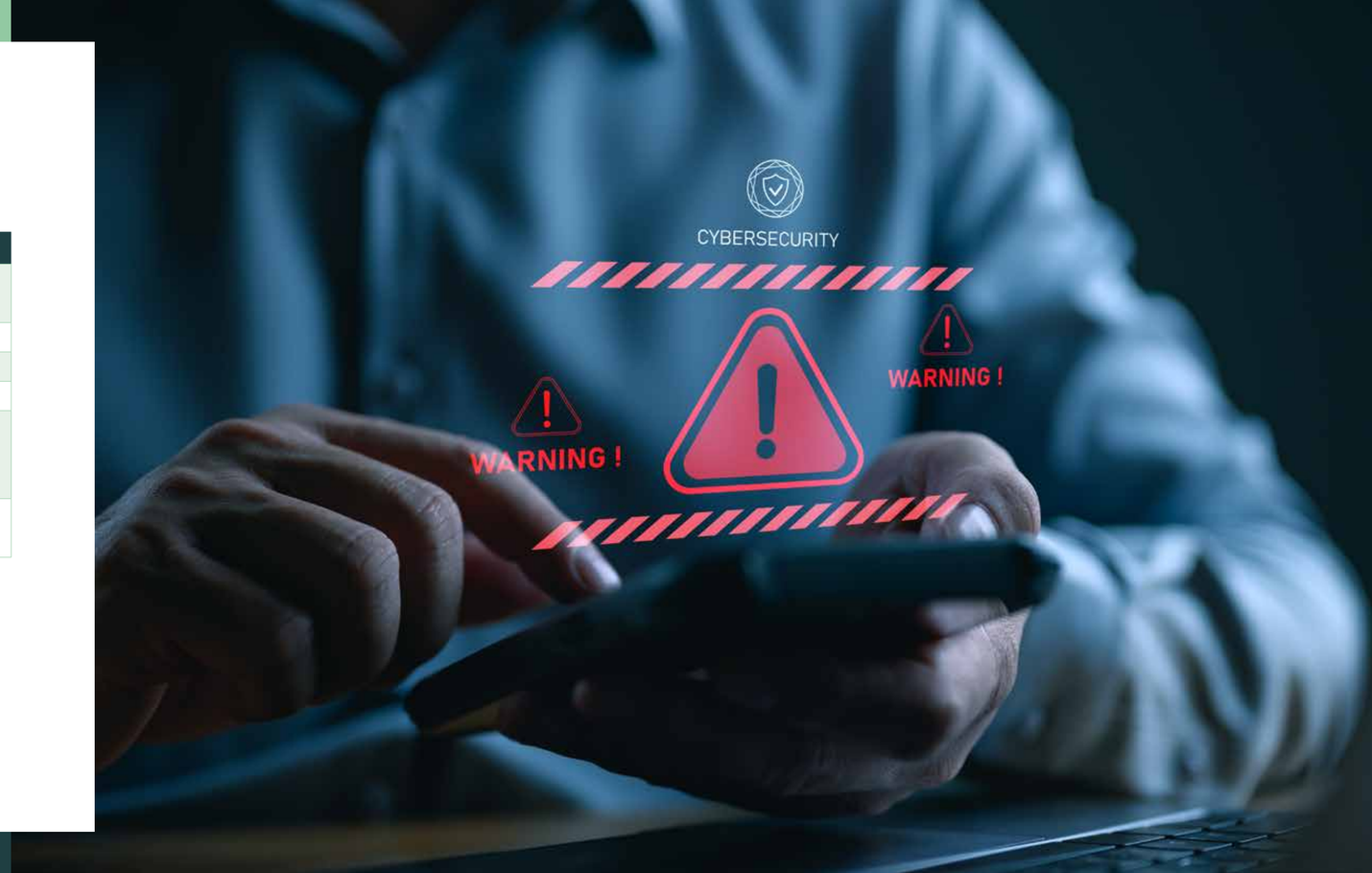
In het kader van het huidige dreigingslandschap zijn er een paar aanbevelingen extra actueel:

- Beperk de sessieduur bij webapplicaties, bijvoorbeeld tot één dag, en stel strengere limieten in voor beheeraccounts en sessies vanaf onbeheerde devices.
- In de cloud van Microsoft bestaan policies die vereisen dat sommige websessiecookies alleen gehonoreerd worden als ze op managed devices gebruikt worden [39].
- Optimaliseer incident response-plannen, logging en detectieoplossingen voor websessiecookie-diefstal.
- Houd wachtwoordmanagers en browsers up-to-date om kwetsbaarheden te vermijden die infostealers kunnen misbruiken.
- Overweeg het gebruik van een adblocker-oplossing om malafide advertenties te blokkeren.

Dreiging - Malware gericht op gebruikers, vervolg

Algemene aanbevelingen

Aanbeveling	CIS control
Voorkom, detecteer en beperk de impact van malware met beheermaatregelen uit CIS controls.	2, 9, 10 + 13.7
Beveilig webbrowsers tegen malafide extensies en pushmeldingen.	9.4
Voer awareness-trainingen uit om menselijke fouten te minimaliseren.	14
Maak een incident response-plan voor malware-infecties.	17
Zorg voor uitgebreide logging om de acties van malware op zowel netwerkniveau als op geïnfecteerde systemen te kunnen traceren, detecteren en waar mogelijk automatisch actie te kunnen ondernemen. Denk bijvoorbeeld aan het blokkeren van verdachte activiteit of het isoleren van geïnfecteerde systemen.	8
Beperk waar mogelijk BYOD-apparaten vanwege o.a. de verhoogde kans op malware en datalekken. Maak waar dat niet mogelijk is gebruik van MDM of MAM.	



Dreiging Financiële fraude

Dreiging - Financiële fraude

Financiële fraude in de Nederlandse zorg is regelmatig in het nieuws geweest. Het gaat bijvoorbeeld om fraude met diploma's, declaraties voor niet geleverde zorg en andere criminaliteit [40]. Deze voorbeelden vallen buiten de scope van dit dreigingsbeeld. In dit hoofdstuk gaat het om financiële fraude waarbij digitale media zoals e-mail en chatapplicaties ingezet worden. Z-CERT schat het dreigingsniveau van digitale financiële fraude in op 'medium'. De impact van financiële fraude was in 2024 beperkt. Z-CERT verwacht in 2025 op wekelijkse basis pogingen tot digitale financiële fraude.

Incidenten en impact

De helft van de respondenten van het onderzoek van Z-CERT gaf aan dat er pogingen zijn geweest tot financiële fraude. In een aantal gevallen heeft dit geleid tot enige schade in de vorm van het versturen van cadeaubonnen naar de kwaadwillende. Eén op de vijf respondenten geeft aan nepfacturen te hebben ontvangen of pogingen te hebben gezien om bankrekeningen te laten aanpassen. Bij één ziekenhuis en één organisatie in de eerstelijnszorg heeft dit geleid tot een salarisbetaling op een 'foute' bankrekening. De impact kan ook groter zijn: een Nederlandse gemeente betaalde bijvoorbeeld een nepfactuur van een ton [41].

Trends, methoden en technieken

Voor deze vorm van fraude worden diverse communicatiemiddelen ingezet zoals e-mail, WhatsApp, sms, telefoon enzovoorts. Z-CERT merkt dat de pogingen zich ook richten op medewerkers die nog maar net in dienst zijn. In de eerste werkweek krijgen ze direct een spoedverzoek, zogenaamd van de directeur. We vermoeden dat dit gebeurt op basis van informatie die geautomatiseerd van LinkedIn wordt afgehaald. Het is dus nuttig om nieuwe medewerkers hier op hun eerste werkdag expliciet voor te waarschuwen. Een voorbeeld van financiële fraude buiten de zorgsector is de Bunq-bank die in 2024 last heeft gehad van deze vorm van fraude via een videogesprek waarin in beeld en geluid de directeur werd nagebootst [42]. Ook internationaal zijn er steeds meer voorbeelden van dit type fraude. Z-CERT verwacht dat de frequentie van dit type incident zal toenemen en ook in de nabije toekomst zich zal voordoen in de Nederlandse zorg.

Algemene aanbevelingen

- Het handelingsperspectief uit het dreigingsbeeld van vorig jaar is nog steeds actueel. Zie de factsheet van Z-CERT zelf over dit onderwerp [43].
- Deelnemers van Z-CERT benutten de chatkanalen van Z-CERT steeds vaker om elkaar over dit soort campagnes te informeren. Zo helpen zorgaanbieders elkaar bij het voorkomen van fraude.

Inschatting dreiging: Medium

Dreiging
Ransomware in de leveranciersketen

Dreiging - Ransomware in de leveranciersketen

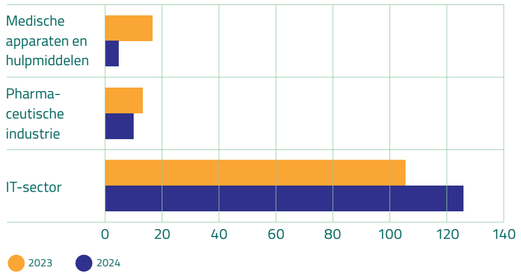
Inschatting dreiging: Hoog

Z-CERT schat het dreigingsniveau voor incidenten door ransomware en/of afpersen met datalekken bij leveranciers van zorginstellingen in als 'hoog'. Dit kunnen IT-leveranciers zijn, maar net zo goed leveranciers buiten het IT-domein. Hoe groter de afhankelijkheid, hoe groter de mogelijke impact. In 2025 verwacht Z-CERT enkele incidenten met impact op de zorgsector.

Incidenten en impact

Op datalekwebsites van ransomware-actoren ontdekte Z-CERT twee incidenten bij leveranciers van zorginstellingen waarbij gegevens van deelnemers waren gelekt. In één geval ging het om gegevens van drie deelnemers, en in het andere incident betrof het gegevens van vijftien ziekenhuizen. Ook waren er drie leveranciers geraakt waardoor meerdere zorginstellingen hun remote toegang van deze bedrijven preventief dichtzetten. Daarnaast lekte een wachtwoord uit van een zorginstelling bij een leverancier die geraakt was door ransomware. Er zijn in 2024 geen incidenten waargenomen waarbij de impact groot was op Nederlandse zorginstellingen. Toch stelt Z-CERT de dreiging niet naar beneden bij. In Europa blijken de IT-dienstverleners nog een gewild doelwit. De hoeveelheid incidenten in deze categorie nam wel met 16% af. De farmaceutische industrie had een vergelijkbare hoeveelheid incidenten als vorig jaar en in de sector van medische apparaten en hulpmiddelen was de hoeveelheid incidenten zelfs meer dan twee keer zo hoog.

Figuur 4: incidenten in Europa in sectoren die leveren aan de gezondheidszorg



Incidenten in Europa waarbij sprake was van afpersing door te dreigen data te lekken en/of data te versleutelen, uitgesplitst in sectoren.

Dreiging - Ransomware in de leveranciersketen, vervolg

Dit jaar (2024) legde een aantal incidenten pijnlijk bloot hoe afhankelijk de zorgsector soms is van leveranciers. Het ging om leveranciers van fysieke en digitale producten en diensten.

Ransomware in de bloedvoorzieningsketen

In 2024 vielen wereldwijd drie ransomware-incidenten op bij dienstverleners in de bloedvoorzieningsketen [44]. We belichten hier één casus om de potentiële impact van dergelijke aanvallen te illustreren.

Op 2 juni 2024 werd Synnovis, een pathologische dienstverlener in Engeland, geraakt door ransomware. Dit had grote impact op zeven ziekenhuizen en de huisartsenzorg in Zuidoost-Londen. In mindere mate was er impact op GGZ, omliggende ziekenhuizen en andere lokale zorgverleners [45]. Het incident had gevolgen voor:

- Patiëntveiligheid: het ransomware-incident leidde tot 498 incidenten met impact op de patiënt veiligheid; 114 van deze incidenten werden ingeschaald [46] als 'low harm' en vijf als 'moderate harm' [47]. Nog 91 incidenten zijn in onderzoek.
- Zorgverlening: Door het incident moesten 10.152 acute poliklinische afspraken en 1.710 geplande ingrepen worden uitgesteld [48].
- Datalek: Van naar schatting 900.000 patiënten lekten persoonsgegevens, waaronder gevoelige medische gegevens, naar het darkweb [49].
- Huisartsenzorg: Tientallen huisartspraktijken in het zuidoosten van Londen konden geen bloedtesten uitvoeren of moesten zich beperken tot urgente gevallen [45].
- Logistieke uitdagingen: Bloedtestresultaten moesten handmatig worden afgedrukt en fysiek worden bezorgd, wat leidde tot vertragingen in behandelbeslissingen [45].
- Nationale bloedvoorraad: Er volgde een dringende oproep voor bloeddonaties voor bloedgroep O. De nationale bloedvoorraden bevonden zich in een 'zeer fragiele positie', waarbij overwogen werd om bloed alleen voor bepaalde gevallen beschikbaar te stellen [50].

Aanval op EPD-leverancier

In de nacht van 11 op 12 februari vond er in Roemenië een ransomware-aanval plaats op een leverancier van een EPD-oplossing. Bij 26 ziekenhuizen werd er data versleuteld [51] door ransomware. 79 andere zorginstellingen moesten hun systemen preventief offline halen en hun netwerk controleren op ransomware [52]. De meeste zorginstellingen konden back-ups terugzetten die één tot drie dagen oud waren. In één geval was er alleen een back-up beschikbaar die twaalf dagen oud was.

Aanval op betalingsverwerker voor de zorgsector

In februari 2024 werd Change Healthcare uit de VS geraakt door een ransomware-incident. Change Healthcare vervult een belangrijke rol in de Amerikaanse gezondheidszorg als intermediair voor financiële transacties en verzekeringsverificatie. Het incident had daarom grote gevolgen voor ziekenhuizen, klinieken, apotheken en tandartspraktijken. Ook ondervonden zorgorganisaties bijvoorbeeld problemen bij het indienen en verwerken van declaraties, het controleren van verzekeringen van patiënten en het ontvangen van betalingen. Dit leidde tot cashflow-problemen en operationele uitdagingen voor veel zorgverleners, waarbij sommige organisaties zelfs nieuwe patiënten moesten weigeren. Uiteindelijk heeft Change Healthcare de ransomware-eis van de aanvallers betaald. Dit was een bedrag van 22 miljoen dollar (ongeveer 21 miljoen euro).

Specifieke aanbevelingen voor 2025

In het kader van het huidige dreigingslandschap zijn er een paar aanbevelingen extra actueel:

- Identificeer, classificeer en prioriteer leveranciers of andere derde partijen die van belang zijn voor het uitoefenen van kritieke functies. Ook niet-IT leveranciers kunnen van belang zijn! Zie het document van het NCSC "Hoe breng ik mijn rechtstreekse leveranciers in kaart?" [53].
- Ontwikkel continuïteitsprocedures om in geval van ransomware-incidenten bij deze partijen toch de kritieke functies te kunnen blijven uitoefenen. Houd daarbij rekening met de hersteltijd van ransomware-incidenten. Bijna twee-derde van de leveranciers herstelt binnen een maand, bij de overige incidenten duurt het langer [54].
- Zorg dat er een incident response plan is voor incidenten bij leveranciers. In sommige gevallen moet bijvoorbeeld besloten worden de externe toegang dicht te zetten.
- Zorg waar mogelijk dat in geval van nood gebruik gemaakt kan worden van alternatieve leveranciers of inkoop-/goederenstromen.
- Test en actualiseer met enige regelmaat de continuïteitsplannen en downtime procedures.

Algemene aanbevelingen

Zie ook het handelingsperspectief in het hoofdstuk 'Ransomware bij zorginstellingen". De genoemde aanbevelingen zijn ook toepasbaar op leveranciers.

Dreiging
DDoS

Dreiging - DDoS

Inschatting dreiging: Medium

Z-CERT schat het dreigingsniveau voor DDoS-aanvallen op zorginstellingen in op 'medium'. Hoewel DDoS-aanvallen wereldwijd zijn toegenomen, stond de zorgsector dit jaar niet in de top 10 van meest aangevallen sectoren. In 2024 had de Nederlandse zorgsector minder last van DDoS-aanvallen dan in 2023. Geopolitieke ontwikkelingen hebben niet geleid tot een toename van het aantal incidenten. Z-CERT verwacht dit jaar enkele DDoS-incidenten met geringe impact op Nederlandse zorginstellingen. Het jaar 2023 heeft laten zien dat dit plotseling kan omslaan.

Incidenten en impact

In 2024 had de Nederlandse zorgsector minder last van DDoS-incidenten dan in 2023. De meeste door Z-CERT waargenomen aanvallen vonden buiten Europa plaats (zie onderstaande afbeelding). Slechts twee zorginstellingen hebben in 2024 DDoS-incidenten gemeld die gericht waren op hun eigen infrastructuur.

Fig 5 Aantal DDoS-aanvallen die gericht waren op de zorgsector

1e kwartaal

Totaal Nederland	0
Totaal Europa*	2
Totaal buiten Europa	5
Totaal	**7**

2e kwartaal

Totaal Nederland	0
Totaal Europa*	0
Totaal buiten Europa	6
Totaal	**6**

3e kwartaal

Totaal Nederland	1
Totaal Europa*	0
Totaal buiten Europa	12
Totaal	**13**

4e kwartaal

Totaal Nederland	1
Totaal Europa*	4
Totaal buiten Europa	6
Totaal	**11**

*Zonder Nederland

Dreiging - DDoS, vervolg

In 2024 was er maar één melding door een ziekenhuis van een DDoS-aanval. In 2023 werd er nog door vijftien ziekenhuizen overlast door DDoS-aanvallen gemeld.

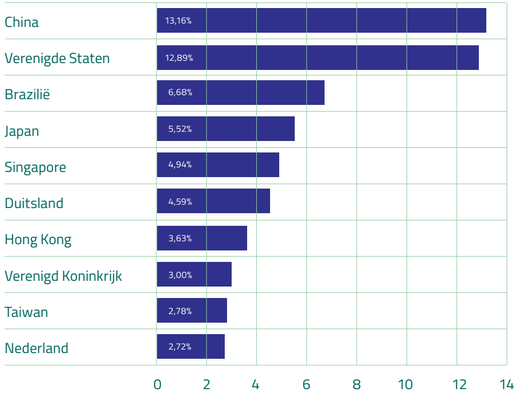
De in 2024 gemelde aanval op een ziekenhuis bestond uit twee korte DDoS-aanvallen met een hoog volume die kort op elkaar volgden. De internetprovider van het ziekenhuis constateerde dat de aanval uit het buitenland kwam.Na overleg met Z-CERT heeft het ziekenhuis de door de provider geadviseerde maatregelen getroffen om de aanval af te slaan.

Bij een grote GGZ-instelling was er een aanval op het werknemersportaal. Deze had als impact dat de GGZ-instelling gedurende 1,5 uur inlogvertraging ondervond op het portaal. De aanval is uiteindelijk verholpen door het inzetten van een DDoS-wasstraat. Een dag later volgde een nieuwe DDoS-aanval, ook gericht op een IP-adres van de GGZ-instelling. Deze aanval is succesvol gemitigeerd. Bij beide DDoS-incidenten is de motivatie van de aanvaller onbekend.

Geo-locatie van aanvallende servers

In 2024 zijn DDoS-aanvallen op Nederland vanuit meer verschillende landen gekomen. In de onderstaande afbeelding is te zien dat tijdens de meting van 1 januari 2025 China op de eerste plek staat met 13,16 procent, maar de Verenigde Staten volgt niet ver daarachter met 12,89 procent. Nederlandse servers stonden nog net in de top 10 met 2,72 procent van het verkeer.

Figuur 6: Statistiek over de bron van het verkeer bij DDoS-aanvallen met Nederland als doelwit. Meting van 1 januari 2025 over de 12 voorgaande maanden [55].



Een reden dat Nederlandse servers afgelopen jaar gebruikt konden worden voor DDoS-aanvallen was doordat wereldwijd TP-Link and Netgear routers zijn overgenomen door middel van bekende kwetsbaarheden [56]. Het is bij Z-CERT onbekend of routers uit de Nederlandse zorg het afgelopen jaar zijn gebruikt bij het uitvoeren van DDoS-aanvallen, maar we sluiten deze mogelijkheid niet uit.

Dreiging - DDoS, vervolg

Trends, methoden en technieken

Volgens Cloudflare is het aantal DDoS-aanvallen wereldwijd met ongeveer 50 procent gestegen ten opzichte van 2023, maar aanvallen van een hoog volume waren meestal kortdurend. Slechts 3 procent van de aanvallen duurde langer dan een uur. De meeste aanvallen kwamen van servers uit Indonesië, gevolgd door Nederland. De zorgsector stond niet in de top 10 van meest aangevallen sectoren [57]. Microsoft meldt een viervoudige toename van DDoS-aanvallen ten opzichte van 2023. DDoS-aanvallen worden volgens Microsoft ook moeilijker te detecteren, doordat ze steeds meer lijken op legitieme webverzoeken [58].

Specifieke aanbevelingen voor 2025

In het kader van het huidige dreigingslandschap zijn er een paar aanbevelingen extra actueel:

- Werk samen met cloud- en internetproviders voor betere DDoS-afweer. Cloud- en internetproviders zijn beter in staat om grote DDoS-aanvallen te verwerken dan individuele zorginstellingen.
- Maak een incidentresponse-plan, continuïteitsprocedures en overweeg simulaties van aanvallen om zwakke plekken te identificeren en effectief te reageren. Inventariseer de afhankelijkheden van externe diensten, bepaal per dienst de maximale uitvaltijd en zorg ervoor dat dit overzicht actueel blijft.
- Patch bekende kwetsbaarheden: DDoS-aanvallen worden steeds vaker gelanceerd vanuit een wereldwijd verspreid netwerk van servers, inclusief servers in Nederland. Voorkom dat uw routers en servers onderdeel worden van zo'n netwerk en patch bekende kwetsbaarheden zo snel mogelijk.

Algemene aanbevelingen

- Factsheet Continuïteit van onlinediensten [59].
- Factsheet Technische maatregelen voor continuïteit voor onlinediensten [60].

Dreiging
DDoS bij leveranciers

Dreiging - DDoS bij leveranciers

Inschatting dreiging: Medium

Z-CERT schat het dreigingsniveau voor DDoS-aanvallen op leveranciers van zorginstellingen in op 'medium'. Verschillende sectoren die aan de zorg leveren waren doelwit, zoals telecom- en serviceproviders en informatietechnologie & diensten [57]. Door de verdere ver-'SaaS'-ing van de zorgsector verwacht Z-CERT in 2025 meerdere DDoS-incidenten met impact op Nederlandse zorginstellingen.

Incidenten en impact

In 2023 gaf 17 procent van de mensen aan last te hebben gehad van DDoS-aanvallen op de infrastructuur van een leverancier. In 2024 is dit gedaald naar 10 procent. Ondanks deze daling, was er wel degelijk impact op de zorg:

- Bij de helft van de incidenten was er beperkte toegang tot de cloudomgeving.
- Enkele websites van zorginstellingen waren niet toegankelijk door DDoS-aanvallen op de hostingprovider van de website.
- Eén zorginstelling kon niet meer werken in het Elektronisch Patiënten Dossier (EPD), omdat de hostingprovider van het EPD te maken had met een DDoS-aanval.
- De Azure-diensten van Microsoft waren in juli negen uur niet beschikbaar door een grootschalige DDoS-aanval [61]. Dit had ook impact op de Nederlandse zorg.
- Tot slot was er een zorginstelling die aangaf impact te hebben gehad door een DDoS-incident bij een grote leverancier van een systeem voor het uitwisselen van gegevens tussen huisartsen.

Specifieke aanbevelingen voor 2025

In het kader van het huidige dreigingslandschap zijn er een paar aanbevelingen extra actueel:

- Samenwerken voor bescherming: Bespreek met uw leverancier hoe zij samenwerken met hun cloud- en internetproviders voor betere DDoS-bescherming.
- Ga uit van incidentele onderbrekingen! De door u aangeschafte SaaS-oplossing zal enkele keren in het jaar kortstondig niet beschikbaar zijn. Dit hoeft niet altijd aan de leverancier te liggen, maar kan ook komen door een DDoS-aanval op de hostingprovider van de leverancier. Zorg dat u een alternatief proces op orde hebt om de continuïteit van zorgprocessen te kunnen waarborgen.

Dreiging
Cyberspionage door statelijke actoren

Dreiging - Cyberspionage door statelijke actoren

Inschatting dreiging:
Hoog of laag*

Z-CERT schat het dreigingsniveau voor cyberspionage door statelijke actoren voor de verschillende typen zorgorganisaties anders in. Voor statelijke cyberactoren is de Nederlandse zorgsector vooral relevant vanwege het stelen van wetenschappelijke onderzoek, intellectuele eigendommen en grote datasets aan medische- en persoonsgegevens. Voor zorgorganisaties die beschikken over dergelijke gegevens, schat Z-CERT de dreiging van cyberspionage door statelijke actoren in als 'hoog'. Voor andere type zorgorganisaties schat Z-CERT de dreiging van cyberspionage door statelijke actoren in als 'laag'. Z-CERT verwacht dat cyberspionage in 2025 actueel zal blijven.

Naast de genoemde intentie wordt de hoge dreiging ook veroorzaakt doordat statelijke aanvallers goed georganiseerd zijn en over veel technische vaardigheden beschikken om hun opdrachten heimelijk uit te voeren.

Incidenten en impact

Bij Z-CERT zijn geen incidenten bekend van cyberspionage door statelijke actoren in de Nederlandse en Europese zorgsector. In de Verenigde Staten is dit jaar een cybercampagne bekendgemaakt waarbij onder andere Amerikaanse gezondheidsorganisaties zijn aangevallen door een Iraanse statelijke actor. Deze Iraanse statelijke actor heeft voor spionagedoeleinden toegang verkregen tot de Amerikaanse slachtoffers. Vervolgens zijn hackers uit deze groep, waarschijnlijk zonder mandaat van de Iraanse overheid en voor eigen persoonlijk financieel gewin, ransomware gaan inzetten bij de Amerikaanse slachtoffers. Daarbij is samengewerkt met twee bekende Russische ransomware-groepen [62]. Deze cybercampagne laat zien dat technologisch hoogwaardige cybercapaciteiten van statelijke actoren en de expertise van ransomware-groepen samen kunnen gaan..

Landen met een offensief cyberprogramma

Z-CERT is dit jaar meermaals om advies gevraagd hoe zorgorganisaties moeten omgaan met hard- en software van leveranciers uit landen met een offensief cyberprogramma. Dit betreft landen die door de Nederlandse inlichtingendiensten worden onderzocht op ongewenste en heimelijke cyberoperaties gericht tegen Nederlandse belangen. Per land verschilt de mate van dreiging van spionage (en sabotage) voor de Nederlandse zorgsector. Met name vanuit China is de spionagedreiging zorgelijk omdat veel innovatieve (zorg)producten in dit land worden geproduceerd en doorontwikkeld. Daarbij bestaat het risico dat buitgemaakte (zorg)data via een in China ontwikkeld en/of beheerd product wordt gebruikt voor 'data-analyse' doeleinden, anders dan voor de gebruikelijke

*Afhankelijk van type organisatie

Dreiging - Cyberspionage door statelijke actoren, vervolg

productondersteuning- en ontwikkeling [63]. De AIVD schrijft hierover in zijn jaarverslag het volgende: "China heeft inmiddels een vooraanstaande positie op het gebied van kunstmatige intelligentie (AI). Om die te houden en uit te breiden, hongert het land naar meer data. China probeert op reguliere manieren aan technologie, kennis en data te komen, bijvoorbeeld door samenwerking met westerse technologiebedrijven, universiteiten en onderzoeksinstituten. Maar het land gebruikt evengoed (cyber) spionage. China probeert in het Westen ook gevoelige bedrijfsinformatie te stelen om zijn eigen economische positie sterker te maken" [64]. Chinese bedrijven en personen zijn bovendien bij wet verplicht om vergaarde data, zoals data gegenereerd door medische IoT-apparatuur, te delen met de Chinese inlichtingendiensten [65].

"Z-CERT vindt spionagedreiging uit China zorgelijk. Europese samenwerking noodzakelijk."

Trends, methoden en technieken

Digitale spionagegroepen zijn technologische voorlopers. In onderstaande tekst worden enkele voorbeelden genoemd die in 2024 niet direct de zorgsector hebben geraakt, maar indirect en/of op termijn dit wel kunnen gaan doen.

- Een Russische digitale spionagegroep, zeer waarschijnlijk onderdeel van de Russische inlichtingendienst, heeft deels zijn aandacht verlegd naar het verkrijgen van toegang tot de cloudomgevingen van zijn doelwitten. Dit deden de Russische cyberspionnen onder meer via bruteforce- en password spray-aanvallen gericht tegen serviceaccounts. Dit soort accounts worden veelal gebruikt voor het geautomatiseerd beheren van één of meerdere applicaties en diensten en hebben vaak veel toegangsrechten. Dit soort serviceaccounts werken dus zonder menselijke gebruiker, waardoor MFA niet is ingeschakeld. Daarmee zijn dit soort accounts extra kwetsbaar. En serviceaccounts worden vaak uitgesloten van policies, zoals het periodiek wijzigen van het wachtwoord. Als dat zo is en de cyberspion weet onder de radar te blijven, heeft hij langdurig netwerktoegang met verhoogde toegangsrechten. De Russische spionagegroep in kwestie heeft voornamelijk Westerse overheidspartijen, denktanks, gezondheids-organisaties en energiebedrijven als doelwit gehad, en richt zijn pijlen recent ook op onderwijsinstellingen en andere sectoren [66].
- Hybride-oorlogsvoering is ook in 2024 een belangrijk thema geweest. Behalve het Rusland-Oekraïne conflict zijn is ook het Israël-Hamas conflict een belangrijke katalysator geweest voor hybride-oorlogsvoering. Zo heeft de Iraanse CyberAv3ngers groep, gelieerd aan de Iraanse Republikeinse garde, succesvolle aanvallen uitgevoerd op operationele technologie (OT) van Unitronics (een Israëlisch bedrijf) bij waterbedrijven in de Verenigde Staten en Europa. Deze OT wordt ook gebruikt in medische apparaten [67] [68]. De intentie van deze Iraanse groep was zeer waarschijnlijk het verstoren van operationele processen bij de waterbedrijven. Hybride-oorlogsvoering is dus niet alleen spionage, maar vooral ook het verspreiden van desinformatie en het plegen van, vooralsnog, beperkte sabotage.
- Kunstmatige intelligentie wordt ook door statelijke cyberactoren gebruikt, bijvoorbeeld als kennisbron om informatie over een doelwit te verzamelen, eenvoudige scripts te schrijven en inhoud te verzamelen of te generen voor phishingaanvallen. Op deze manieren is onder andere het OpenAI platform misbruikt door Chinese, Iraanse, Russische en Noord-Koreaanse hackers [69] [70].

Specifiek aanbevelingen

De risico's van statelijke cyberspionage uit dit hoofdstuk kunnen beperkt worden door het nemen van diverse maatregelen:

- Veel van de gebruikte tactieken en technieken zoals beschreven in de hoofdstukken over ransomware, phishing en malware, worden ook gebruikt door cyberspionnen. Voor aanbevelingen verwijzen we naar deze hoofdstukken.
- Z-CERT vindt het aan de organisaties zelf om een risicoanalyse te maken en de risico's af te wegen tegen de noodzaak van het gebruik van de betreffende hard- en/of software [71]. Met name de noodzaak om iets te gebruiken kan van organisatie tot organisatie verschillen. Het is praktisch vrijwel onuitvoerbaar om elk component van alle hardware en software, inclusief medische apparaten en domotica in kaart te brengen. Ontwikkelingen zoals een Software Bill Of Materials [72] kunnen hier in de toekomst steeds beter bij helpen.
- De beste en meest recente adviezen over hoe cloudserviceaccounts het best beveiligd kunnen worden zijn te lezen op de website van de cloudprovider [73] [74] [75].
- Voor specifieke technieken gebruikt voor aanvallen op OT-apparatuur verwijzen we naar een advies van CISA [76].

Dreiging Insider threats

Dreiging - Insider threats

Inschatting dreiging: Medium

De categorie 'insider threats' is omvangrijk. In dit dreigingsbeeld is een selectie gemaakt van incidenten die dit jaar zijn gemeld bij Z-CERT. Het gaat om datalekken die het gevolg waren van onopzettelijkheid, nalatigheid, nieuwsgierigheid en kwaadwillend handelen door insiders. Waarbij insiders worden gedefinieerd als interne medewerkers, voormalige medewerkers, ingehuurd personeel, leveranciers of andere derde partijen. Z-CERT schat deze dreiging in op 'medium' en de frequentie varieert sterk per type. Z-CERT verwacht voor 2025 een vergelijkbaar beeld als in 2024.

Incidenten en impact

De onderstaande tabel geeft de mate aan waarin dit type dreiging heeft plaatsgevonden onder de respondenten.

	Vraag	Nooit	Weinig	Gemiddeld	Veel	Zeer veel
Onopzettelijk	**Hoe vaak kwamen datalekken voor die in de categorie 'onopzettelijk' vallen?**					
	Verkeerd bezorgd (mail)	2	32	32	30	4
	Patiënt- of cliëntverwissleing bij het invoeren van gegevens in het EPD/ECD	26	36	20	14	4
	Publicatie fout (bestanden op verkeerde plek, bv. website, intranet, SharePoint)	50	32	14	4	0
	Misconfiguratie (bv. in webapplicatie)	58,3	35,4	6,3	0	0
Nalatig	**Hoe vaak kwamen datalekken voor die in de categorie 'nalatig' vallen?**					
	Onjuiste rechten (onterecht behoud rechten, rechten groep verkeerd etc.)	18	52	18	10	2
	Onbeheerde openstaande schermen	24,5	34,7	22,4	12,2	6,3
	Ongeoorloofd gebruik van cloudgebaseerde AI chatbots (zoals ChatGPT)	44,9	26,5	20,4	6,1	2
	Verlies of diefstal van apparaten (smartphone, laptop etc.)	40,8	42,9	12,2	4,1	0
	Ongeoorloofd gebruik van cloudgebaseerde opslag- en samenwerkingsapps	49	34,7	12,2	4,1	0
Nieuwsgierig of kwaadwillend	**Hoe vaak kwamen datalekken voor die in de categorie 'nieuwsgierig en kwaadwillend' vallen?**					
	Ongeoorloofde inzage EPD/ECD of andere uitslagenbronnen (nieuwsgierigheid)	29,2	58,3	10,4	2,1	0
	Ongeoorloofde inzage EPD/ECD of andere uitslagenbronnen (kwaadwillend)	85,4	14,6	0	0	0
	Datalek door toedoen van een ontevreden medewerker van leverancier/partner	91,7	8,3	0	0	0
	Datalek door toedoen van een ontevreden medewerker	93,8	6,3	0	0	0
	Datalek door toedoen van een ontevreden ex-medewerker	95,8	4,2	0	0	0

Dreiging - Insider threats, vervolg

AI chatbots

Uit de tabel blijkt dat er regelmatig datalekken ontstaan door het gebruik van AI-chatbots. De Autoriteit Persoonsgegevens (AP) heeft in 2024 meerdere meldingen ontvangen van datalekken waarbij medewerkers gevoelige informatie van patiënten of cliënten in AI-chatbots hebben ingevoerd [77]. Zorginstellingen geven aan dat ze moeite hebben om zicht te houden op de gegevens die met chatbots worden gedeeld. Tegelijkertijd zijn er ook positieve voorbeelden in de zorg waar deze chatbots een meerwaarde hebben [78]. Het is belangrijk dat zorginstellingen en medewerkers de risico's van het delen van data met chatbots kennen.

- Het delen van (bijzondere) persoonsgegevens met AI-chatbots kan ertoe leiden dat aanbieders van deze chatbots ongeoorloofde toegang krijgen tot deze data [77].
- Het delen van (bijzondere) persoonsgegevens met AI-chatbots kan in strijd zijn met de Algemene Verordening Gegevensbescherming (AVG), zelfs als interne beleidsregels dit toestaan [77].
- Gevoelige gegevens kunnen in handen van cybercriminelen vallen door gecompromitteerde chatbot-accounts, vaak via malware gestolen en op het darkweb verkocht [79].
- Patiënten en cliënten moeten geïnformeerd worden over het gebruik van AI-chatbots en de doeleinden waarvoor hun gegevens worden verwerkt [80].

Aanbevelingen:

- De AI Act verplicht organisaties om te zorgen voor 'AI-geletterdheid' bij medewerkers die gebruik maken van AI-oplossingen [80]. In februari 2025 zal de website 'Informatieveilig gedrag in de zorg' een kennisproduct uitbrengen dat dieper ingaat op hoe zorgmedewerkers kunnen omgaan met AI. [81]
- Overweeg het implementeren van Data Loss Prevention (DLP)-oplossingen om te detecteren of te voorkomen dat persoonsgegevens worden gedeeld met AI-chatbots.
- Bied een goedgekeurde AI-chatbotoplossing aan waarop een DPIA is uitgevoerd, en waarvan is vastgesteld dat die voldoet aan de AVG en de privacy- en veiligheidsnormen van de organisatie.

Ongeoorloofde inzage

Ongeoorloofde inzage kwam het afgelopen jaar regelmatig voor en is meestal het gevolg van nieuwsgierigheid, vaak gericht op het eigen dossier of dat van bekenden. Dit gebeurt meestal uit persoonlijke interesse.

Kwaadwillende inzage was zeldzaam in 2024. Een bekend voorbeeld betreft een GGD-geval waarin iemand zich zonder BIG-registratie voordeed als arts en toegang kreeg tot dossiers. In een ander geval had een medewerker binnen korte tijd ongewoon veel cliëntendossiers ingezien zonder geldige reden.

Organisaties hebben moeite om de volledige impact van deze dreiging in kaart te brengen. Dit komt omdat ze afhankelijk zijn van de meldingsbereidheid van zorgmedewerkers en omdat de loggingdata te omvangrijk is om volledig te controleren. Tegelijkertijd komen er steeds meer oplossingen die mogelijke onterechte inzagen signaleren. Denk hierbij aan controles die waarschuwen wanneer een medewerker zonder behandelrelatie inzage heeft in een dossier van een patiënt of cliënt die in de buurt woont. Z-CERT ziet dat ECD's en EPD's steeds meer functies hebben om deze ongewenste inzagen te detecteren.

Aanbevelingen:

- Loggingcontrole ligt gevoelig. Betrek daarom medewerkers, de Ondernemingsraad, bestuur en andere stakeholders bij het opzetten van loggingcontrole.
- Bewustwording eerst: informeer medewerkers dat patiëntgegevens alleen voor functiegerelateerd gebruik zijn en dat logging wettelijk verplicht is en opvraagbaar door patiënten en cliënten.
- Logging is een controlemiddel; voorkom onrechtmatige inzagen ook op andere manieren door bijvoorbeeld rechten te beperken en nood-inzagefunctionaliteit te gebruiken.
- Ontwerp een autorisatiematrix gebaseerd op zorgprocessen. Deze matrix kan dienen als basis voor het automatiseren van loggingcontroles.
- Pas voor automatische loggingcontrole 'business rules' toe die ongeoorloofde inzage van gegevens detecteren. Regels die kijken naar uitzonderingen op normaal gedrag van werknemers zijn krachtig. Bijvoorbeeld een client waarvoor vandaag 50 procent meer dossier-inzagen zijn geweest dan gebruikelijk.
- Bespreek potentiële onterechte inzagen met de betrokken medewerker(s).

Dreiging - Insider threats, vervolg

Datalek door toedoen ontevreden (ex-) medewerker of een (ex-) medewerker van een leverancier

Uit het onderzoek van Z-CERT blijkt dat er onder ondervraagden weinig incidenten voorkomen die het gevolg zijn van ontevreden (ex-) medewerkers. Wel werden er een aantal incidenten bij Z-CERT gemeld dit jaar.

Bij één incident werd een dienstverband beëindigd van een medewerker met beheeraccounts. Een event in de persoonlijke sfeer triggerde naderhand dat deze persoon dreigde misbruik te maken van opgedane kennis voor een aanval op de IT-infrastructuur van de organisatie. Bij een ander geval vertrok een medewerker bij een organisatie en downloadde een grote hoeveelheid data. De twee casussen hadden uiteindelijk geen grote impact, maar het kan ook anders uitpakken. Ook uitdiensttreding van personeel bij een leverancier kan gevolgen hebben voor een zorgorganisatie. Bij één geval dit jaar was er een medewerker uit dienst bij een leverancier, maar was het account niet tijdig gedeactiveerd. Twee dagen nadat de medewerker uit dienst ging, kon hij inloggen en patiëntengegevens van ongeveer één miljoen patiënten buitmaken [82].

Specifieke aanbevelingen

Leveranciers	CIS control
Monitor leveranciers op hun activiteiten bijvoorbeeld door middel van een privileged access management systeem.	15.6
Pas moderne authenticatie principes toe bij leveranciers	5, 6
Onderzoek voorafgaand aan de samenwerking met een leverancier welke maatregelen zijn getroffen om incidenten te voorkomen. Het is belangrijk dat de maatregelen wat betreft toegang en accountmanagement ook bij uitdiensttreding van medewerkers tijdig worden toegepast.	15.5
(Ex-)medewerkers	**CIS control**
Pas moderne authenticatie principes toe bij leveranciers	5, 6
▪ Neem maatregelen op het gebied van accountmanagement, accessmanagement en auditlogmanagement. Zorg ervoor dat processen voor het blokkeren van accounts en het intrekken van rechten tijdig worden uitgevoerd wanneer iemand uit dienst gaat. Dit soort processen kunnen geautomatiseerd worden door integraties met HR-systemen. ▪ Als iemand met beheerrechten uit dienst gaat, overweeg dan om wachtwoorden van serviceaccounts of API-sleutels te wijzigen die toegang geven tot de assets van zorginstelling.	5, 6, 8, 4.11

Algemene aanbevelingen

Raadpleeg de nieuwe publicatie van het NCSC genaamd 'Omgaan met insider threats' over het managen van de insiders threats [83].

Conflict Rusland en Oekraïne

Dreigingsscenario's conflict Rusland en Oekraïne

Het conflict tussen Oekraïne en Rusland blijft een bron van onzekerheid. Volgens de AIVD is de dreiging richting Nederland significant [84]. In dit artikel delen we een aantal dreigingsscenario's op cybergebied die in Oekraïne (en soms daarbuiten) zijn waargenomen. Op het moment van schrijven acht Z-CERT alleen het eerste scenario actueel. De andere scenario's zijn momenteel onwaarschijnlijk, maar het is belangrijk om deze dreigingen te kennen voor risicoanalyses, business continuity plannen en om de weerbaarheid te verhogen.

DDoS-aanvallen op thuiswerk- en domotica-omgevingen

Doelgerichte DDoS-aanvallen van hacktivisten op zorginstellingen waren vaak gericht op de website. De impact van dit soort aanvallen is beperkt. Echter er zijn ook enkele aanvallen bij Z-CERT bekend op de thuiswerk- of domotica-omgevingen. Veel van deze aanvallen zijn niet doelgericht, maar gericht op een cloudprovider of internetprovider.

Verstoring van het GPS-signaal

Tijdens de oorlog in Oekraïne werd vaak het GPS-signaal verstoord voor oorlogsdoeleinden. Ook buiten het oorlogsgebied werd hier overlast van ondervonden [85]. In de zorg worden GPS-signalen gebruikt voor diverse toepassingen zoals dwaaldetectie en persoonsalarmering. Verstoringen kunnen impact hebben op het functioneren van deze oplossingen/diensten.

Uitval van internetconnectiviteit

In Oekraïne waren er regelmatig aanvallen op internetproviders. De impact van de aanvallen was beperkt omdat het land een groot aantal internetproviders heeft. Ook het gebruik van satellietinternetverbindingen speelde een rol bij het opvangen van verstoringen.

Misbruik van kwetsbaarheden

Tijdens de oorlog hadden Oekraïense organisaties soms last van "hack en lek"-operaties of werden websites gehackt om propaganda te verspreiden. Pro-Russische actoren hebben ingezet op het misbruik van kwetsbaarheden in internet-ontsloten apparaten, zoals firewalls en VPN-oplossingen.

Wiperware

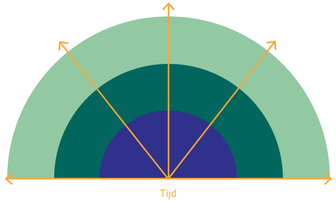
In Oekraïne werd veelvuldig wiperware ingezet [86]. Dat is malware die eropuit is zoveel mogelijk data te vernietigen.

Voor meer informatie en input voor uw risicoanalyses verwijzen we door naar het document "Vier cybersecuritylessen uit één jaar oorlog in Oekraïne" van het NCSC.

Uitleg bij de dreigingsradar

De dreigingsradar is gebaseerd op het Factor Analysis of Information Risk framework (kortweg FAIR) (https://www.fairinstitute.org) om dreigingen naar prioriteit te wegen. Het model is ontwikkeld in het Shared Research Programma (SRP) Cyber Security dat is gecoördineerd door TNO. Hieraan hebben ook partners als ING, ABN AMRO, Rabobank, Volksbank en Achmea deelgenomen.

Het is verdeeld in een 3x3 matrix en geeft de tijd en impact weer van cyberdreigingen in de zorg. De impact van een dreiging kan laag/middel/hoog zijn. De tijdlijn is verdeeld in de situatie op het moment van schrijven, de situatie die is te verwachten op korte termijn (binnen 1 jaar) of de dreigingen die in de toekomst (over meer dan 1 jaar) impact kunnen gaan hebben.



De positionering van de diverse bolletjes (met impact laag/middel/hoog) in de radarfiguur hangt samen met de weging van de dreiging in relatie tot de tijd. Is er op dit moment een bepaalde dreiging te signaleren, dan zal de dreiging met het daaraan verbonden nummer gepositioneerd worden in het radargedeelte van actuele dreigingen. Is een bepaald type dreiging op korte termijn te verwachten, binnen nu en één jaar, dan zal de betreffende dreiging worden gepositioneerd in de tweede ring. Tenslotte blikken wij ook vooruit en dreigingen die Z-CERT verwacht over meer dan 1 jaar zullen geplaatst worden in de buitenste ring.

De plaatsing van de bolletjes geeft bovendien de ernst van de dreiging aan. In de rechter taartpunt staan de ernstigste dreigingen. Hoe meer de bolletjes naar links staan, hoe lager de dreiging is die ervan uitgaat.

Kleur	Impact
	Hoog
	Gemiddeld
	Laag

De inschaling van de impact en de positie van de dreiging is gebaseerd op een rekenmodel van TNO. De geschatte tijd is gebaseerd op kennis van experts.

Dankwoord

We danken iedereen die heeft meegewerkt aan de productie van dit Cybersecurity Dreigingsbeeld voor de zorg, onder wie een aantal reviewers van zorginstellingen, CISO's en security specialisten van verschillende zorginstellingen.

We willen met name onze dank uitbrengen aan:

Nationaal Cyber Security Centrum (NCSC)

Ewald Beekman (Amsterdam UMC)

Erick van Veghel (Catharina Ziekenhuis)

Joost Bakker (BovenIJ ziekenhuis)

Jelmer Modderman (Nij Smellinghe Ziekenhuis)

Jan Ebbes (RIBW K/AM)

Winrik Campo (Aafje)

Aico Hoekman (Siza)

Niels Fontein (Siza)

Richard Binnekamp (GGD GHOR Nederland)

Adrie Rolloos (Parnassia Groep)

Vormgeving: Z-CERT, februari 2025

Bibliografie

[1] **Google Cloud**, "UNC3944 Targets SaaS Applications," 13 Juni 2024. [Online]. Available: https://cloud.google.com/blog/topics/threats-intelligence/unc3944-targets-saas-applications/.

[2] **CISA**, "#StopRansomware: BianLian Ransomware Group," 2024 November 2024. [Online]. Available: https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-136a.

[3] **"Ransomware's Evolving Threats: The Rise of RansomHub, Decline of Lockbit, and the New Era of Data Extortion,"** 1 November 2024. [Online]. Available: https://blog.checkpoint.com/research/ransomwares-evolving-threats-the-rise-of-ransomhub-decline-of-lockbit-and-the-new-era-of-data-extortion/.

[4] **Coveware**, "Ransomware actors pivot away from major brands in Q2 2024," 29 Juli 2024. [Online]. Available: https://www.coveware.com/blog/2024/7/29/ransomware-actors-pivot-away-from-major-brands-in-q2-2024.

[5] **B. Toulas**, "Cyberattack at French hospital exposes health data of 750,000 patients," 20 November 2024. [Online]. Available: https://www.bleepingcomputer.com/news/security/cyberattack-at-french-hospital-exposes-health-data-of-750-000-patients/.

[6] **SecurityWeek**, "Fortinet Data Breach Impacts Customer Information," 13 September 2024. [Online]. Available: https://www.securityweek.com/fortinet-data-breach-impacts-customer-information/.

[7] **Google Cloud**, "UNC5537 Targets Snowflake Customer Instances for Data Theft and Extortion," 10 Juni 2024. [Online]. Available: https://cloud.google.com/blog/topics/threats-intelligence/unc5537-snowflake-data-theft-extortion.

[8] **Sophos**, "The State of Ransomware in Healthcare 2024," 2024. [Online]. Available: https://www.sophos.com/en-us/whitepaper/state-of-ransomware-in-healthcare.

[9] **A. Delamotte**, "The State of Cloud Ransomware in 2024," 14 November 2024. [Online]. Available: https://www.sentinelone.com/blog/the-state-of-cloud-ransomware-in-2024/.

[10] **Microsoft**, "Storm-0501: Ransomware attacks expanding to hybrid cloud environments," [Online]. Available: https://www.microsoft.com/en-us/security/blog/2024/09/26/storm-0501-ransomware-attacks-expanding-to-hybrid-cloud-environments/.

[11] **A. Büyükkaya**, "Ransomware in the Cloud: Scattered Spider Targeting Insurance and Financial Industries," 2 Oktober 2024. [Online]. Available: https://blog.eclecticiq.com/ransomware-in-the-cloud-scattered-spider-targeting-insurance-and-financial-industries.

[12] **CERT-EU**, "Security Guidance 22-001 - Cybersecurity mitigation measures against critical threats," 9 Maart 2022. [Online]. Available: https://cert.europa.eu/publications/security-guidance/security-guidance-22-001---cybersecurity-mitigation-measures-against-critical-threats/.

[13] **U.S. Cybersecurity and Infrastructure Security Agency**, U.S. Federal Bureau of Investigation, New Zealand's Government Communications Security Bureau, New Zealand's Computer Emergency Response Team, Canadian Centre for Cyber Security, "MODERN APPROACHES TO NETWORK ACCESS SECURITY," 18 juni 2024. [Online]. Available: https://www.ic3.gov/CSA/2024/240618.pdf.

[14] **NCSC**, " Factsheet Omgaan met edge devices," 10 Juni 2024. [Online]. Available: https://www.ncsc.nl/documenten/factsheets/2024/juni/10/kennisproduct-omgaan-met-edge-devices.

[15] **NCSC**, " Incidentresponsplan Ransomware," 3 Juni 2022. [Online]. Available: https://www.ncsc.nl/documenten/publicaties/2022/juni/3/incidentresponsplan-ransomware.

[16] **Center for Internet Security**, "CIS Critical Security Controls®," [Online]. Available: https://www.cisecurity.org/controls. [Geopend November 2024].

[17] **Microsoft**, "Security baselines," 2024. [Online]. Available: https://learn.microsoft.com/en-us/windows/security/operating-system-security/device-management/windows-security-configuration-framework/windows-security-baselines.

[18] **Google Cloud**, "Ransomware Protection and Containment Strategies," 30 April 2024. [Online]. Available: https://services.google.com/fh/files/misc/ransomware-protection-and-containment-strategies-report-en.pdf.

[19] **Microsoft**, "File hosting services misused for identity phishing," Microsoft, 8 October 2024. [Online]. Available: https://www.microsoft.com/en-us/security/blog/2024/10/08/file-hosting-services-misused-for-identity-phishing/.

Bibliografie, vervolg

[20] **Microsoft**, "Microsoft Digital Defense Report 2024," Microsoft, 2024.

[21] **Sekoia**, "Tycoon 2FA: an in-depth analysis of the latest version of the AiTM phishing kit," Sekoia, 25 March 2024. [Online]. Available: https://blog.sekoia.io/tycoon-2fa-an-in-depth-analysis-of-the-latest-version-of-the-aitm-phishing-kit/.

[22] **Sekoia**, "Mamba 2FA: A new contender in the AiTM phishing ecosystem," Sekoia, 7 October 2024. [Online]. Available: https://blog.sekoia.io/mamba-2fa-a-new-contender-in-the-aitm-phishing-ecosystem/.

[23] **Unit42**, "Business Email Compromise: Investigating Infrastructure and Tactics of Phishing-as-a-Service Platform Sniper Dz," Palo Alto, 24 September 2024. [Online]. Available: https://unit42.paloaltonetworks.com/phishing-platform-sniper-dz-unique-tactics/.

[24] **Zscaler**, "Phishing Attacks Rise: ThreatsLabz 2024 Phishing Report," Zscaler, 23 April 2024. [Online]. Available: https://www.zscaler.com/blogs/security-research/phishing-attacks-rise-58-year-ai-threatslabz-2024-phishing-report.

[25] **Verizon**, "Verizon 2024 Data Breach Investigations," 2024.

[26] **Nederland Digitaal**, "AI-gegenereerd aas maakt phishing nog gevaarlijker," 8 januari 2025. [Online]. Available: https://www.nederlanddigitaal.nl/actueel/nieuws/2025/01/08/ai-gegenereerd-aas-maakt-phishing-nog-gevaarlijker.

[27] **S. L. A. K. B. S. A. V. Fred Heiding**, "Evaluating Large Language Models' Capability to Launch Fully Automated Spear Phishing Campaigns: Validated on Human Subjects," 30 november 2024. [Online]. Available: https://arxiv.org/abs/2412.00586.

[28] **M. Greenfield**, "The Diary of a CEO: A tale of how an AI deepfake spear phishing attack was thwarted," 10 oktober 2024. [Online]. Available: https://www.quodorbis.com/the-diary-of-a-ceo-a-tale-of-how-an-ai-deep-fake-spear-phishing-attack-was-thwarted/.

[29] **NCSC**, "Factsheet 'Volwassen authenticeren – gebruik veilige middelen voor authenticatie'," 25 April 2022. [Online]. Available: https://www.ncsc.nl/documenten/factsheets/2022/april/24/factsheet-volwassen-authentiseren-gebruik-veilige-middelen-voor-authenticatie.

[30] **Microsoft**, "What is Conditional Access?," Microsoft, 3 March 2024. [Online]. Available: https://learn.microsoft.com/en-us/entra/identity/conditional-access/overview.

[31] **Microsoft**, "Detecting and mitigating a multi-stage AiTM phishing and BEC campaign," 8 Juni 2023. [Online]. Available: https://www.microsoft.com/en-us/security/blog/2023/06/08/detecting-and-mitigating-a-multi-stage-aitm-phishing-and-bec-campaign/.

[32] **Zolder**, "Using honeytokens to detect (AiTM) phishing attacks on your Microsoft 365 tenant," Zolder, 9 January 2024. [Online]. Available: https://zolder.io/blog/using-honeytokens-to-detect-aitm-phishing-attacks-on-your-microsoft-365-tenant/.

[33] **Zolder**, Did somewone clone me, "Why DSCM?," [Online]. Available: https://didsomeoneclone.me/find-website-copies-why-and-how/.

[34] **Microsoft**, "IT Admins - Manage external meetings and chat with people and organizations using Microsoft identities," 1 Juni 2023. [Online]. Available: https://learn.microsoft.com/en-us/microsoftteams/trusted-organizations-external-meetings-chat?tabs=organization-settings.

[35] **Microsoft**, "How Microsoft Defender for Office 365 innovated to address QR code phishing attacks," Microsoft, 4 November 2024. [Online]. Available: https://www.microsoft.com/en-us/security/blog/2024/11/04/how-microsoft-defender-for-office-365-innovated-to-address-qr-code-phishing-attacks/#MicrosoftDefender.

[36] **NEN**, "NEN Connect," 1 december 2024. [Online]. Available: https://connect.nen.nl/Standard/Detail/3716055.

[37] **Recorded future**, "H1 2024: Malware and Vulnerability Trends Report," 10 September 2024. [Online]. Available: https://www.recordedfuture.com/research/h1-2024-malware-and-vulnerability-trends-report.

[38] **Blackberry**, "Global Threats Intelligence Rapport," 2024. [Online]. Available: https://www.blackberry.com/us/en/pdfviewer?file=/content/dam/bbcomv4/blackberry-com/en/solutions/threats-intelligence/threats-report/sept2024/Global-Threats-Intelligence-Report_Sept-2024.pdf.

[39] **Microsoft**, "Conditional Access: Token protection," 27 juni 2024. [Online]. Available: https://learn.microsoft.com/en-us/entra/identity/conditional-access/concept-token-protection.

[40] **RTL**, https://www.rtl.nl/nieuws/binnenland/artikel/5478149/zware-criminelen-dringen-de-zorg-binnen.

Bibliografie, vervolg

[41] **Nu.nl**, "Gemeente Helmond trapt in nepaanmaning en is bijna ton kwijt," nu.nl, 25-11-2024. Available: https://www.nu.nl/binnenland/6336745/gemeente-helmond-trapt-in-nepaanmaning-en-is-bijna-ton-kwijt-menselijke-fout.html.

[42] **Computerweekly**, https://www.computerweekly.com/news/366572934/Dutch-organisations-vulnerable-to-deepfake-fraud.

[43] **Z-CERT**, https://z-cert.nl/kennisbank/phishing-fraude/factsheet-financiele-fraude.

[44] **American Hospital Association and Health-ISAC**, "American Hospital Association and Health-ISAC Joint Threats Bulletin - TLP White," 1 Juli 2024. [Online]. Available: https://www.aha.org/advisory/2024-08-01-american-hospital-association-and-health-isac-joint-threats-bulletin-tlp-white.

[45] **The Guardian**, "London NHS hospitals revert to paper records after cyber-attack," 5 Juni 2024. [Online]. Available: https://www.theguardian.com/society/article/2024/jun/05/london-nhs-hospitals-revert-to-paper-records-in-wake-of-russian-cyber-attack.

[46] **NHS**, "Policy guidance on recording patient safety events and levels of harm," 9 Oktober 2024. [Online]. Available: https://www.england.nhs.uk/long-read/policy-guidance-on-recording-patient-safety-events-and-levels-of-harm/.

[47] **DigitalHealth**, "Synnovis attack led to at least five cases of 'moderate' patient harm," 12 November 2024. [Online]. Available: https://www.digitalhealth.net/2024/11/synnovis-attack-led-to-at-least-five-cases-of-moderate-patient-harm/.

[48] **NHS England**, "Update on cyber incident: Clinical impact in south east London – Thursday 26 September 2024," 26 September 2024. [Online]. Available: https://www.england.nhs.uk/london/2024/09/26/update-on-cyber-incident-clinical-impact-in-south-east-london-thursday-26-september-2024/.

[49] **Alexander Martin**, "Data on nearly 1 million NHS patients leaked online following ransomware attack on London hospitals," 16 September 2024. [Online]. Available: https://therecord.media/data-on-nearly-1-million-nhs-patients-leaked-hospital-ransomware.

[50] **A. Martin**, "UK national blood stocks in 'very fragile' state following ransomware attack," 18 Juli 2024. [Online]. Available: https://therecord.media/uk-blood-stocks-ransomware-attack-london-hospitals.

[51] **DNSC**, "ALERTĂ: Backmydata Ransomware," 15 Februari 2024. [Online]. Available: https://www.dnsc.ro/citeste/alert-backmydata-ransomware-spitale-romania.

[52] **S. Gatlan**, "Ransomware attack forces 100 Romanian hospitals to go offline," 12 Februari 2024. [Online]. Available: https://www.bleepingcomputer.com/news/security/ransomware-attack-forces-100-romanian-hospitals-to-go-offline/.

[53] **NCSC**, " Hoe breng ik mijn rechtstreekse leveranciers in kaart?," [Online]. Available: https://www.ncsc.nl/wat-kun-je-zelf-doen/weerbaarheid/herkennen/hoe-breng-ik-mijn-rechtstreekse-leveranciers-in-kaart.

[54] **Sophos**, "The state of ransomware 2024," 2024. [Online]. Available: https://www.sophos.com/en-us/whitepaper/state-of-ransomware.

[55] **Cloudflare**, [Online]. Available: https://radar.cloudflare.com/security-and-attacks/nl?dateRange=52w.

[56] **F5**, [Online]. Available: https://www.f5.com/labs/articles/threats-intelligence/sensor-intel-series-top-cves-april-2024.

[57] **Cloudflare**, [Online]. Available: https://blog.cloudflare.com/ddos-threats-report-for-2024-q3/.

[58] **Microsoft**, [Online]. Available: https://www.microsoft.com/en-us/security/security-insider/intelligence-reports/microsoft-digital-defense-report-2024.

[59] **NCSC**, " Factsheet Continuïteit van online diensten," 2 Maart 2023. [Online]. Available: https://www.ncsc.nl/documenten/factsheets/2019/juni/01/factsheet-continuiteit-van-onlinediensten.

[60] **NCSC**, "Factsheet Technische maatregelen voor continuïteit voor online diensten," 2 Maart 2023. [Online]. Available: https://www.ncsc.nl/documenten/factsheets/2019/juni/01/factsheet-technische-maatregelen-voor-continuiteit-van-online-diensten.

Bibliografie, vervolg

[61] **Bleepingcomputer**, [Online]. Available: https://www.bleepingcomputer.com/news/microsoft/microsoft-says-massive-azure-outage-was-caused-by-ddos-attack/.

[62] **Aha**, "Iran-based Cyber Actors Enabling Ransomware Attacks on U.S. Organizations," August 2024. [Online]. Available: https://www.aha.org/advisory/2024-08-29-iran-based-cyber-actors-enabling-ransomware-attacks-us-organizations.

[63] **Reuters**, "China's WuXi AppTec shared US client's data with Beijing, US intelligence officials told senators," March 2024. [Online]. Available: https://www.reuters.com/technology/chinas-wuxi-apptec-shared-us-clients-data-with-beijing-us-intelligence-officials-2024-03-28/.

[64] **AIVD**, "Jaarverslag 2023 AIVD," 2024. [Online]. Available: https://www.aivd.nl/documenten/jaarverslagen/2024/04/22/jaarverslag-2023.

[65] **DNI**, "China's Collection of Genomic and Other Healthcare Data," February 2021. [Online]. Available: https://www.dni.gov/files/NCSC/documents/SafeguardingOurFuture/NCSC_China_Genomics_Fact_Sheet_2021revision20210203.pdf.

[66] **NCSC**, "SVR cyber actors adapt tactics for initial cloud access," February 2024. [Online]. Available: https://www.ncsc.gov.uk/news/svr-cyber-actors-adapt-tactics-for-initial-cloud-access.

[67] **MITRE**, "MITRE ATT&CK - Unitronics Defacement Campaign," March 2024. [Online]. Available: https://attack.mitre.org/campaigns/C0031/.

[68] **The Record**, "Two-day water outage in remote Irish region caused by pro-Iran hackers," December 2023. [Online]. Available: https://therecord.media/water-outage-in-ireland-county-mayo.

[69] **OpenAI**, "Disrupting malicious uses of AI by state-affiliated threats actors," February 2024. [Online]. Available: https://openai.com/index/disrupting-malicious-uses-of-ai-by-state-affiliated-threats-actors/.

[70] **Rijksoverheid**, "Versterkte dreigingen in een wereld vol kunstmatige intelligentie," December 2024. [Online]. Available: https://www.rijksoverheid.nl/documenten/rapporten/2024/12/09/tk-bijlage-versterkte-dreigingen-in-een-wereld-vol-kunstmatige-intelligentie.

[71] **Loket Kennisveiligheid**, "Nationale leideraad kennisveiligheid - veilig internationaal samenwerken," Januari 2022. [Online]. Available: https://www.loketkennisveiligheid.nl/binaries/loketkennisveiligheid/documenten/rapporten/2022/01/14/nationale-leidraad-kennisveiligheid/Nationale-leidraad-kennisveiligheid.pdf.

[72] **NCSC**, "Software Bill of Materials (SBOM) Wat, waarom en hoe?," Juli 2023. [Online]. Available: https://www.ncsc.nl/binaries/ncsc/documenten/publicaties/2023/juli/5/sbom-startersgids/123TNOdv_SBOM_V3b.pdf.

[73] **Microsoft**, "Microsoft - Securing cloud-based service accounts," October 2023. [Online]. Available: https://learn.microsoft.com/en-us/entra/architecture/secure-service-accounts.

[74] **AWS**, "AWS - Securing your account," December 2024. [Online]. Available: https://docs.aws.amazon.com/prescriptive-guidance/latest/aws-startup-security-baseline/controls-acct.html.

[75] **Google**, "Google - Best practices for using service accounts," December 2024. [Online]. Available: https://cloud.google.com/iam/docs/best-practices-service-accounts.

[76] **CISA**, "IRGC-Affiliated Cyber Actors Exploit PLCs in Multiple Sectors, Including US Water and Wastewater Systems Facilities," 18 December 2024. [Online]. Available: https://www.cisa.gov/news-events/cybersecurity-advisories/aa23-335a.

[77] **AP**, "Let op: gebruik AI-chatbot kan leiden tot datalekken," 6 Augustus 2024. [Online]. Available: https://www.autoriteitpersoonsgegevens.nl/actueel/let-op-gebruik-ai-chatbot-kan-leiden-tot-datalekken.

[78] **Z-CERT**, "AI in de zorg," August 2024. [Online]. Available: https://z-cert.nl/actueel/nieuws/ai-in-de-zorg.

[79] **Graham Cluley** , "100,000 hacked ChatGPT accounts up for sale on the dark web," 2023. [Online]. Available: https://www.bitdefender.com/en-us/blog/hotforsecurity/100-000-hacked-chatgpt-accounts-up-for-sale-on-the-dark-web.

[80] **I. Khoe,** "Verantwoord omgaan met AI-chatbots in de zorg," 19 September 2024. [Online]. Available: https://www.ictrecht.nl/blog/hoe-ga-je-verantwoord-om-met-ai-chatbots-in-de-zorg.

Bibliografie, vervolg

[81] **Stichting ECP**, "Veilig gedrag, sterke zorg," [Online]. Available: https://www.informatieveiliggedragzorg.nl/.

[82] **Geisinger**, "Geisinger provides notice of Nuance's data security incident," 24 Juni 2024. [Online]. Available: https://www.geisinger.org/about-geisinger/news-and-media/news-releases/2024/06/24/18/17/geisinger-provides-notice-of-nuances-data-security-incident.

[83] **NCSC**, "Omgaan met insider threats," nr. https://www.ncsc.nl/documenten/publicaties/2024/februari/29/omgaan-met-insider-threats.

[84] **AIVD**, "AIVD: 2025 wordt een onrustig jaar," 19 December 2024. [Online]. Available: https://www.aivd.nl/actueel/nieuws/2024/12/19/aivd-2025-wordt-een-onrustig-jaar.

[85] **BBC**, "Russia blamed for GPS interference affecting flights in Europe," 2 Mei 2024. [Online]. Available: https://www.bbc.com/news/articles/cne900k4wvjo.

[86] **NCSC**, " Vier cybersecuritylessen uit één jaar oorlog in Oekraïne," 21 Februari 2023. [Online]. Available: https://www.ncsc.nl/documenten/publicaties/2023/februari/21/vier-cybersecuritylessen-uit-een-jaar-oorlog-in-oekraine.

De Nederlandse zorg digitaal veilig

Stichting Z-CERT - Stationsplein 121, 3818 LE Amersfoort

033 737 06 09 - info@Z-CERT.nl - Z.CERT.nl - LinkedIn.com/company/z-cert